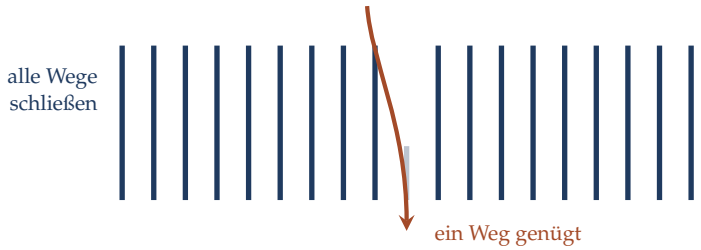
Informatik von Grund auf — Band 19

Der schwächste Punkt

Sicherheit



Warum Systeme brechen und woran

Jeder Schritt erklärt. Mit vollständig durchgerechneten Übungsaufgaben.

Stand der Forschung: August 2026

Informatik von Grund auf — Band 19
Der schwächste Punkt · Sicherheit

Herausgeber und Urheber: Jürgen Maier
Entstanden 2026 in Zusammenarbeit mit Claude (Anthropic); Konzeption, Vorgaben, Prüfung und Herausgeberschaft: Jürgen Maier.

Lizenz
Dieses Werk ist lizenziert unter einer Creative-Commons-Lizenz **Namensnennung – Weitergabe unter gleichen Bedingungen 4.0 International (CC BY-SA 4.0)**. Sie dürfen das Werk vervielfältigen, verbreiten, bearbeiten und auch kommerziell nutzen, sofern Sie den Urheber nennen und Bearbeitungen unter derselben Lizenz weitergeben.
Lizenztext: `https://creativecommons.org/licenses/by-sa/4.0/legalcode.de`

Quellen und Fassungen
Quelltexte, Fehlermeldungen und aktuelle Fassungen aller Bände:
`https://github.com/juergenmaier2026/informatik-von-grund-auf`
Schwesterreihe: *Mathematik von Grund auf*, `https://doi.org/10.5281/zenodo.23698547`

Zitiervorschlag
Maier, J. (2026). *Informatik von Grund auf, Band 19: Der schwächste Punkt*. Fassung 1.0.0.
`https://github.com/juergenmaier2026/informatik-von-grund-auf`

Satz: LaTeX mit Palatino. Fassung 1.0.0, Oktober 2026. 150 Seiten.

Inhaltsverzeichnis

Vorwort **1**

I Die Denkweise **9**

1 Die Asymmetrie **11**

2 Das Angreifermodell **19**

3 Angriffsfläche und Vertrauensgrenzen **27**

II Wo Systeme brechen **35**

4 Speicherfehler **37**

5 Eingaben und Einschleusung **45**

6 Rechte und Identität **51**

III Das Umfeld **59**

7 Konfiguration und Voreinstellungen **61**

8 Die Lieferkette **67**

9 Der Mensch **75**

IV Was sich verrät **83**

10 Seitenkanäle **85**

11 Kryptographie in der Anwendung **91**

12 Protokolle und Zustände **99**

V Verteidigung **107**

13 Härten **109**

14 Erkennen und Reagieren **117**

VI Bilanz **125**

15 Der Stand im Jahr 2026 **127**

VII Anhang **133**

A Formeln und Kenngrößen **135**

B Landkarte und Glossar **139**

C Zeittafel **141**

D Kommentierte Quellen **143**

Vorwort: Eine Lücke genügt

Dieser Band handelt nicht von Kryptographie. *Band 8 behandelt die Mathematik — RSA, Diffie-Hellman, Signaturen. Systeme fallen fast nie, weil diese Mathematik gebrochen wurde. Sie fallen an Vertrauensgrenzen, Annahmen, Voreinstellungen, Lieferketten und Menschen.*

Die Asymmetrie

	Verteidiger	Angreifer
Muss	**alle Wege schließen**	**einen finden**
Kennt	sein System	sucht sich aus, was er lernt
Zeit	begrenzt	unbegrenzt
Fehler	einer genügt	folgenlos
Erfolg heißt	nichts geschieht	einmal reicht

Aus dieser Tabelle folgt fast alles Weitere. Sie erklärt, warum Sicherheit teuer und Unsicherheit billig ist; warum eine Kette so stark ist wie ihr schwächstes Glied; und warum „wir haben nichts gefunden" keine Aussage über die Sicherheit eines Systems ist.

Die Folge für die Sprache.

Leer	„Das System ist sicher"
Sinnvoll	**Das System widersteht *diesem* Angreifer mit *diesen* Mitteln bei *diesem* Ziel**
Der Grund	Ohne Angreifermodell gibt es keine prüfbare Behauptung

Sicherheit ist keine Eigenschaft, die ein System hat, sondern eine Aussage über ein Verhältnis. Wer sie ohne Gegenüber behauptet, sagt nichts — ähnlich wie eine Laufzeitangabe ohne Eingabegröße.

Was dieser Band nicht ist

Inhalt	Enthalten?	
Warum Systeme brechen	**ja**	
Fehlerklassen und ihre Ursachen	ja	
Bedrohungs-modellierung	ja	
Verteidigung, Erkennung	ja	
Anleitung zum Einbruch	**nein**	
Werkzeuge und Handgriffe	nein	veraltet in Monaten

Die Trennung ist nicht nur eine Frage des Anstands, sondern der Haltbarkeit. Ein bestimmter Angriff ist in zwei Jahren behoben; die Frage, warum diese Fehlerklasse immer wieder entsteht, gilt seit fünfzig Jahren. Nur die zweite ist ein Buchthema.

Das entspricht auch der Praxis der Standardwerke: Anderson, Bishop und Shostack erklären Mechanismen und Denkweisen, keine Rezepte. Wer Angriffe üben will, braucht eine Umgebung dafür, kein Buch.

Vier Einsichten, die alt sind und ignoriert werden

Einsicht	Seit	Wer
Die Sicherheit darf nicht am Geheimnis des Verfahrens hängen	1883	**Kerckhoffs**
Geringstmögliche Rechte	1975	**Saltzer, Schroeder**
Einfacher Aufbau ist prüfbarer	1975	**Saltzer, Schroeder**
Vertrauen endet nicht beim Quelltext	1984	**Thompson**

Die erste ist hundertdreiundvierzig Jahre alt und wird bis heute verletzt — jedes Mal, wenn ein Verfahren geheim gehalten wird, statt es prüfen zu lassen. Die letzte ist die unbequemste: Thompsons Übersetzer aus dem Begleitband zeigt, dass die Prüfung des Quelltextes nicht genügt.

Was dieses Buch will

Erstens: rechnen, wo gerechnet werden kann.

Angriffsflächen, Passwortentropie und wie schnell sie fällt, Erkennungs- und Fehlalarmraten, Kosten von Maßnahmen gegen erwarteten Schaden, die Wirkung gestufter Verteidigung. Vieles in diesem Fach wird behauptet; einiges ist rechenbar, und dieser Band rechnet es aus.

Zweitens: die Fehlerklassen erklären, nicht die Vorfälle aufzählen.

Klasse	Anteil	Kapitel
Speicherfehler	≈ 60 %	4
Eingabebehandlung	≈ 20 %	5
Rechte und Identität	≈ 12 %	6
Übrige	≈ 8 %	

Die Anteile beziehen sich auf schwere Lücken in systemnaher Software und schwanken je nach Erhebung. Die Größenordnung ist stabil: Zwei Klassen tragen vier Fünftel, und beide sind seit Jahrzehnten bekannt.

Drittens: den Menschen nicht zur Schwachstelle erklären.
Der Satz, der Mensch sei das schwächste Glied, ist bequem und meist falsch. Er beendet die Untersuchung, statt zu fragen, warum ein System es einem Einzelnen erlaubt, durch eine Fehlentscheidung alles zu verlieren.

Drei Warnungen

Erstens: Es gibt keine Sicherheit, nur Kosten.

> *Jede Maßnahme verschiebt das Verhältnis von Aufwand zu Ertrag für den Angreifer. Ein System ist praktisch sicher, wenn der Einbruch mehr kostet, als er einbringt — und diese Aussage hängt am Angreifer, nicht am System.*

Zweitens: Die meisten Vorfälle sind langweilig.

Ursache	Anteil	
Bekannte, ungepatchte Lücke	**hoch**	**Monate bis Jahre alt**
Schwache oder wiederverwendete Zugangsdaten	hoch	
Fehlkonfiguration	hoch	
Bisher unbekannte Lücke	gering	überschätzt

Die letzte Zeile bekommt die Aufmerksamkeit und verursacht den kleinsten Teil des Schadens. Wer seine Mittel nach Schlagzeilen verteilt, sichert gegen das Seltene und lässt das Häufige offen.

Drittens: Sicherheit gegen Bedienbarkeit ist ein falscher Gegensatz.
Eine Maßnahme, die zu umständlich ist, wird umgangen — und ein umgangenes Verfahren schützt nicht. Was die Bedienung erschwert, senkt am Ende die Sicherheit. Band 18 liefert die Begriffe dafür.

Zum Aufbau

- **Teil I** (Kap. 1–3): Die Denkweise. Asymmetrie, **Angreifermodell**, Angriffsfläche.

- **Teil II** (Kap. 4–6): Wo Systeme brechen. Speicher, Eingaben, Rechte.
- **Teil III** (Kap. 7–9): Das Umfeld. Konfiguration, **Lieferkette**, Mensch.
- **Teil IV** (Kap. 10–12): Was sich verrät. Seitenkanäle, Kryptographie in der Anwendung, Protokolle.
- **Teil V** (Kap. 13–15): Verteidigung. Härten, Erkennen, der Stand 2026.

Ein Wurm, der Zentrifugen zerstörte

2010 wurde eine Schadsoftware entdeckt, die etwas tat, was es bis dahin nicht gab: Sie beschädigte physische Anlagen.

Das Ziel	Steuerungen von Anreicherungszentrifugen
Der Weg	**Über getrennte Netze hinweg — vermutlich per Datenträger**
Die Wirkung	Drehzahlen wurden verändert, bis Zentrifugen brachen
Die Tarnung	**Der Leitstand zeigte Normalbetrieb**

Die letzte Zeile verbindet diesen Band mit dem vorigen. Die Anzeige zeigte aufgezeichnete Normalwerte, nicht den Zustand — dieselbe Kluft der Bewertung wie in Three Mile Island, hier absichtlich erzeugt. Ein Angriff auf die Wahrnehmung, nicht nur auf die Maschine.

Was der Fall zeigte.

Netztrennung	Schützt nicht, wenn Datenträger die Grenze überqueren
Aufwand	Mehrere unbekannte Lücken — eine Größenordnung über dem Üblichen
Angreifermodell	**Ein Staat ist ein anderer Gegner als ein Erpresser**

Die dritte Zeile ist die Lehre für Kapitel 2. Gegen einen Angreifer mit Jahren Zeit und staatlichen Mitteln schützt keine Maßnahme, die für Gelegenheitstäter entworfen wurde — und die meisten Anlagen brauchen auch keinen solchen Schutz.

Der Fall wird häufig als Beleg dafür angeführt, dass alles angreifbar sei. Das ist die falsche Lehre. Die richtige lautet: Der Aufwand war außergewöhnlich, und genau deshalb sagt er über den Schutz gewöhnlicher Systeme wenig aus.

Hundertvierzig Jahre Sicherheitsdenken

1883	**Kerckhoffs**	**Die Sicherheit liegt im Schlüssel, nicht im Verfahren**
1961	MIT	erste Passwörter im Zeitteilbetrieb
1972	Anderson	Bericht zur Rechnersicherheit
1974	Lampson	Zugriffsmatrix
1975	**Saltzer, Schroeder**	**acht Entwurfsgrundsätze**
1979	Morris, Thompson	Passwortsicherheit untersucht
1984	**Thompson**	**Reflections on Trusting Trust**
1988	Morris-Wurm	das Netz wird verwundbar
1993	—	Firewalls werden Standard
1995	—	SSL, später TLS
1996	**Kocher**	**Zeitmessung als Angriff**
1996	Aleph One	Pufferüberläufe systematisch erklärt
2000	Schneier	*Secrets and Lies*: Sicherheit ist ein Prozess

2002	Mitnick	**der Mensch als Angriffsweg**
2003	Howard, LeBlanc	sicheres Programmieren als Handwerk
2006	—	Speicherschutzmaßnahmen werden Standard
2010	**Stuxnet**	Schadsoftware zerstört Anlagen
2013	—	Umfang staatlicher Überwachung wird öffentlich
2014	—	Heartbleed: eine fehlende Längenprüfung
2014	**Shostack**	**Bedrohungsmodellierung als Handwerk**
2015	Beurdouche u. a.	**Protokollzustände als Fehlerquelle**
2017	—	Erpressungssoftware trifft Kliniken
2018	**Meltdown, Spectre**	**die Hardware verrät sich**
2020	—	Lieferkettenangriff auf Verwaltungssoftware
2021	—	eine Protokollierbibliothek erschüttert das Netz
2024	—	**Hintertür in einer Kompressionsbibliothek**
2026	—	Werkzeuge finden und schreiben Angriffe

Zwei Zeilen verdienen eine Anmerkung.
1883, Kerckhoffs. Sein Grundsatz war für Feldchiffren gedacht und gilt unverändert: Ein Verfahren, dessen Sicherheit von seiner Geheimhaltung abhängt, ist gebrochen, sobald jemand es beschreibt — und irgendjemand beschreibt es immer.
2024. In eine weit verbreitete Kompressionsbibliothek wurde über Jahre hinweg eine Hintertür eingebracht, durch geduldige Mitarbeit an einem Projekt mit einem einzigen Betreuer. Kapitel 8 behandelt den Fall als das Lehrstück über Vertrauen in Abhängigkeiten.

Sicherheit ist keine Eigenschaft eines Systems.
Sie ist eine Aussage darüber, wie teuer ein Angriff wäre —
für einen bestimmten Angreifer,
mit bestimmten Mitteln, bei einem bestimmten Ziel.

— der Leitgedanke dieses Bandes.
Wer den Gegner nicht benennt, hat nichts behauptet —
und kann nichts prüfen.

Part I

Die Denkweise

1 Die Asymmetrie

Warum Verteidigung teurer ist

Größe	Verteidiger	Angreifer
Zu prüfende Wege	**alle**	**einer**
Aufwand	$\mathcal{O}(n)$	$\mathcal{O}(1)$
Wissen nötig	vollständig	punktuell
Wiederholbarkeit	einmal richtig	beliebig oft versuchen

Die zweite Zeile ist der Kern: Der Aufwand des Verteidigers wächst mit der Größe des Systems, der des Angreifers nicht. Deshalb wird jedes wachsende System relativ unsicherer, wenn der Sicherungsaufwand nicht mitwächst.

Die Wahrscheinlichkeitsrechnung dahinter.
Sei p die Wahrscheinlichkeit, dass ein einzelner Weg gesichert ist. Bei n unabhängigen Wegen gilt

$$P(\text{alle sicher}) = p^n.$$

n	$p = 0{,}99$	$p = 0{,}999$	$p = 0{,}9999$
10	0,904	0,990	0,999
100	0,366	0,905	0,990
1000	**0,00004**	0,368	0,905
10 000	≈ 0	**0,00005**	0,368

Bei tausend Wegen und neunundneunzig Prozent Güte je Weg ist die Wahrscheinlichkeit, dass alles hält, praktisch null. Um dieselbe Gesamtsicherheit bei zehnfacher Größe zu halten, muss die Güte je Weg um eine Größenordnung steigen — nicht um zehn Prozent.

Die Unabhängigkeitsannahme

Fall	Rechnung	
Wege unabhängig	p^n	Idealfall
Gemeinsame Ursache	**deutlich schlechter**	**dieselbe Bibliothek**
Gemeinsamer Entwerfer	schlechter	derselbe Denkfehler

Die Rechnung oben ist die optimistische. *In Wirklichkeit hängen Wege zusammen: Alle benutzen dieselbe Bibliothek, alle wurden von denselben Leuten geschrieben, alle beruhen auf derselben Annahme. Eine Lücke in der gemeinsamen Ursache öffnet viele Wege gleichzeitig.*

Die acht Grundsätze von 1975

SALTZER und SCHROEDER formulierten Entwurfsgrundsätze, die unverändert gelten.

Sparsamer Aufbau	Je einfacher, desto prüfbarer
Grundhaltung: verboten	Erlaubt wird ausdrücklich, nicht durch Auslassung
Vollständige Prüfung	Jeder Zugriff wird geprüft, nicht nur der erste
Offener Entwurf	**Die Sicherheit hängt am Schlüssel, nicht am Geheimnis**
Geteilte Zuständigkeit	Zwei Bedingungen statt einer
Geringste Rechte	**Nur so viel, wie die Aufgabe braucht**
Wenig Gemeinsames	Geteilte Bauteile verbinden, was getrennt sein sollte
Annehmbarkeit	**Was zu umständlich ist, wird umgangen**

Der letzte Grundsatz wird am häufigsten übergangen und ist der wirksamste. Eine Maßnahme, die die Arbeit unzumutbar macht, wird umgangen — und ein umgangenes Verfahren schützt nicht, sondern erzeugt nur die Illusion von Schutz.

Der zweite Grundsatz ist der praktisch folgenreichste. Ein System, das alles erlaubt, was nicht ausdrücklich verboten ist, wird bei jeder Erweiterung unsicherer — weil jede neue Möglichkeit stillschweigend freigeschaltet ist.

Aufgabe 1.1.

(a) Rechnen Sie die Kostenasymmetrie aus.
(b) Bestimmen Sie die Wirkung gestufter Verteidigung.
(c) Prüfen Sie ein System gegen die acht Grundsätze.

Lösung Schritt für Schritt.

(a) Die Kostenasymmetrie.
Die Lage. Ein System mit 40 Schnittstellen.

Tätigkeit	Aufwand	
Prüfung je Schnittstelle	6 h	
Vollständige Prüfung	**240 h**	**Verteidiger**
Suche einer Lücke	≈ 18 h	**Angreifer**
Verhältnis	**13 : 1**	

Der Angreifer prüft nicht alle Schnittstellen, sondern durchschnittlich die Hälfte, bis er fündig wird — und er bricht ab, sobald er eine Lücke hat. Der Verteidiger muss auch die neununddreißig prüfen, die in Ordnung sind.

Bei wachsendem System.

Schnittstellen	Verteidiger	Angreifer	Verhältnis
10	60 h	12 h	5 : 1
40	240 h	18 h	13 : 1
200	1200 h	22 h	**55 : 1**
1000	6000 h	26 h	**231 : 1**

Der Angreiferaufwand wächst kaum, weil er mit der Zahl der Ziele auch mehr Gelegenheiten hat — er sucht nicht länger, er findet früher. Das Verhältnis verschlechtert sich fast linear mit der Systemgröße.

Daraus folgt der wirksamste strategische Griff dieses Bandes: die Zahl der Wege senken. Eine Schnittstelle, die es nicht gibt, muss nicht gesichert werden — und sie kostet auch keine Prüfzeit. Kapitel 3 führt das aus.

(b) Gestufte Verteidigung.
Das Modell. Ein Angreifer muss k Hürden nacheinander überwinden, jede mit Wahrscheinlichkeit q.

$$P(\text{Erfolg}) = q^k.$$

k	$q = 0{,}8$	$q = 0{,}5$	$q = 0{,}3$
1	0,800	0,500	0,300
2	0,640	0,250	0,090
3	0,512	0,125	**0,027**
5	0,328	**0,031**	0,002

Drei mittelmäßige Hürden schlagen eine gute: $0{,}5^3 = 0{,}125$ *gegenüber* 0,3 *bei einer starken. Das ist die Begründung für gestufte Verteidigung — und sie beruht wieder auf der Annahme der Unabhängigkeit.*

Wenn die Hürden abhängig sind.

Aufbau	P **(Erfolg)**	
Drei unabhängige Hürden	0,125	gut
Drei Hürden, ein Passwort	$\approx$ **0,5**	**eine Hürde**
Drei Hürden, ein Netzsegment	$\approx$ 0,4	fast eine

Drei Türen mit demselben Schlüssel sind eine Tür. Das ist der häufigste Trugschluss beim Aufbau gestufter Verteidigung: Man zählt die Hürden und prüft nicht, ob sie voneinander unabhängig sind.

(c) Ein System gegen die Grundsätze prüfen.
Der Gegenstand. Eine Fachanwendung mit Weboberfläche, 12 Jahre gewachsen.

Grundsatz	Erfüllt?	Befund
Sparsamer Aufbau	nein	340 Endpunkte
Grundhaltung verboten	**nein**	**neue Endpunkte offen**
Vollständige Prüfung	teils	nur beim Anmelden
Offener Entwurf	ja	
Geteilte Zuständigkeit	nein	ein Konto genügt
Geringste Rechte	**nein**	**Dienstkonto ist Administrator**
Wenig Gemeinsames	nein	eine Datenbank für alles
Annehmbarkeit	ja	

Zwei von acht. Bemerkenswert ist die Verteilung: Erfüllt sind die beiden, die nichts kosten. Verletzt sind die, die Aufwand oder Verzicht verlangen — und genau die tragen den Schutz.

Die Maßnahmen nach Wirkung je Aufwand.

Maßnahme	Aufwand	Wirkung	Rang
Dienstkonto entrechten	16 h	sehr hoch	**1**
Prüfung bei jedem Zugriff	80 h	sehr hoch	2
Grundhaltung umkehren	40 h	hoch	3
Zweiter Faktor	60 h	hoch	4
Endpunkte abbauen	200 h	mittel	5
Datenbanken trennen	600 h	mittel	6

Die erste Zeile ist typisch: sechzehn Stunden für die größte Einzelwirkung. Ein Dienstkonto mit Verwaltungsrechten verwandelt jede beliebige Lücke in eine vollständige Übernahme — es hebt die Stufung aus Teil (b) auf.

„Wir hatten noch nie einen Vorfall“

Die Aussage	In zwölf Jahren ist nichts passiert
Was sie belegt	Dass nichts *bemerkt* wurde
Die Frage	**Womit hätte man es bemerkt?**

Ohne Aufzeichnung und Auswertung ist die Abwesenheit von Meldungen kein Befund. Die mittlere Zeit bis zur Entdeckung eines Einbruchs wird in Erhebungen regelmäßig in Monaten angegeben — und diese Zahl umfasst nur die entdeckten Fälle.

Es ist derselbe Auswahlfehler wie in Band 13: Man schließt aus dem, was man sieht, auf das, was ist. Kapitel 14 behandelt, was nötig wäre, damit die Aussage etwas bedeutet.

Shostack[24] macht die Asymmetrie zum Ausgangspunkt der Bedrohungsmodellierung; Saltzer und Schroeder[21] formulierten 1975 die acht Grundsätze; Anderson[1] führt sie am Beispiel realer Systeme durch.

2 Das Angreifermodell

Ohne Gegner keine Aussage

Wer	Wer greift an, mit welchem Ziel?
Womit	Welche Mittel, welches Wissen, wie viel Zeit?
Woher	**Welchen Zugang hat er schon?**
Wogegen	Was genau soll geschützt werden?

Erst wenn diese vier Fragen beantwortet sind, wird aus „ist das sicher?“ eine prüfbare Frage. Die dritte wird am häufigsten übersprungen — und sie entscheidet mehr als die anderen drei zusammen.

Die Angreiferklassen.

Klasse	Mittel	Zeit	Ziel
Gelegenheitstäter	gering	Minuten	**das Einfachste**
Massenangriff	mittel	automatisiert	**Zahl der Opfer**
Erpresser	mittel	Tage	Zahlung
Innentäter	**Zugang**	unbegrenzt	wechselnd
Wettbewerber	hoch	Monate	bestimmte Daten
Staat	**sehr hoch**	Jahre	bestimmtes Ziel

Die vierte Zeile ist die unbequemste: Der Innentäter hat den Zugang bereits, gegen den sich alle äußeren Maßnahmen richten. Gegen ihn helfen nur geteilte Zuständigkeit, geringste Rechte und Aufzeichnung — drei Maßnahmen, die niemand gern einführt, weil sie Misstrauen ausdrücken.

Die Kostenschwelle

Die Regel	Ein Angriff findet statt, wenn Ertrag mal Erfolgswahrscheinlichkeit den Aufwand übersteigt
Der Hebel	**Aufwand erhöhen oder Ertrag senken**
Der zweite	Wird selten genutzt und ist oft billiger

Wer Kartennummern nicht speichert, muss sie nicht schützen. Wer Daten nach Ablauf löscht, senkt den Ertrag eines Einbruchs. Diese Maßnahmen kosten meist weniger als jede Absicherung — und wirken gegen alle Angreiferklassen zugleich.

Bedrohungsmodellierung

1	Woran arbeiten wir? — Aufbau, Datenflüsse, Vertrauensgrenzen
2	Was kann schiefgehen? — Bedrohungen je Grenze
3	Was tun wir dagegen? — Maßnahmen oder bewusstes Hinnehmen
4	**Haben wir es gut gemacht?** — Prüfung des Modells selbst

Shostacks vier Fragen sind die brauchbarste Anleitung des Fachs, weil sie ohne Werkzeuge auskommen. Der erste Schritt — ein Diagramm mit eingezeichneten Vertrauensgrenzen — findet erfahrungsgemäß die meisten Probleme, bevor überhaupt über Bedrohungen gesprochen wurde.

Die sechs Bedrohungsarten.

Bedrohung	Verletzt	Gegenmittel
Vortäuschen	Echtheit	Anmeldung
Verfälschen	Unversehrtheit	Prüfsummen, Signaturen
Abstreiten	Nachweisbarkeit	**Aufzeichnung**
Preisgeben	Vertraulichkeit	Verschlüsselung, Rechte
Lahmlegen	Verfügbarkeit	Begrenzung, Reserven
Rechte ausweiten	Befugnis	**geringste Rechte**

Die Liste ist eine Gedächtnisstütze, keine Theorie — ihr Wert liegt darin, dass man an jeder Vertrauensgrenze sechs Fragen stellt statt einer. Wer nur an Preisgeben denkt, übersieht die anderen fünf.

Das häufigste Modellversagen

Annahme	Hält?	
„Nur intern erreichbar“	nein	**ein übernommener Arbeitsplatz genügt**
„Nur unsere App ruft das auf“	nein	
„Der Eingabewert ist geprüft“	nein	von wem?
„Das schafft niemand“	nein	

Alle vier sind Annahmen über den Angreifer, die als Aussagen über das System auftreten. Die erste ist die folgenreichste: Sie setzt das Innennetz mit einer Vertrauenszone gleich — und genau diese Gleichsetzung hat die schweren Vorfälle des letzten Jahrzehnts getragen.

Aufgabe 2.1.

(a) Erstellen Sie ein Angreifermodell für ein Praxissystem.
(b) Rechnen Sie die Kostenschwelle aus.
(c) Zeichnen Sie Vertrauensgrenzen ein und finden Sie die Bedrohungen.

Lösung Schritt für Schritt.

(a) Ein Angreifermodell.
Der Gegenstand. Ein Verwaltungssystem mit personenbezogenen Daten, 200 Arbeitsplätze.

Klasse	Wahrsch.	Schaden	Erwartungswert
Massenangriff	hoch	mittel	**hoch**
Erpresser	hoch	sehr hoch	**sehr hoch**
Innentäter	mittel	hoch	**hoch**
Wettbewerber	gering	mittel	gering
Staat	sehr gering	hoch	gering

Die Rangfolge ist eindeutig, und sie widerspricht der öffentlichen Wahrnehmung: Erpressung und Massenangriff tragen das Risiko, staatliche Angreifer sind für diese Anlage nachrangig. Wer gegen die letzte Zeile härtet, gibt Geld für das Falsche aus.

Die Maßnahmen nach Angreiferklasse.

Maßnahme	Masse	Erpr.	Innen	Staat
Zeitnahe Aktualisierung	++	++	○	+
Zweiter Faktor	++	++	+	+
Getrennte Sicherungen	○	**++**	+	+
Netzsegmentierung	+	++	+	+
Geringste Rechte	+	++	**++**	+
Aufzeichnung	○	+	**++**	+

Fünf der sechs Maßnahmen wirken gegen mehrere Klassen zugleich — das sind die, mit denen man anfängt. Getrennte Sicherungen wirken fast nur gegen Erpressung, sind dort aber der einzige verlässliche Schutz und deshalb trotzdem vorrangig.

(b) Die Kostenschwelle.
Die Rechnung aus Angreifersicht.

Größe	Wert	
Erwarteter Ertrag	80 000	Lösegeld
Erfolgswahr-scheinlichkeit	0,25	
Erwartungswert	**20 000**	
Aufwand	3000	lohnt sich

Nach Maßnahmen.

Zustand	P	Erw.-Wert	Lohnt?
Ohne Maßnahmen	0,25	20 000	ja
Zweiter Faktor	0,09	7200	ja
+ Aktualisierung	0,04	3200	knapp
+ Getrennte Sicherung	0,04	**800**	**nein**

Die letzte Zeile wirkt anders als die darüber: Sie senkt nicht die Erfolgswahrscheinlichkeit des Einbruchs, sondern den Ertrag *— wer seine Daten aus einer unerreichbaren Sicherung wiederherstellen kann, zahlt kein Lösegeld. Der zweite Hebel aus dem Technikkasten, und der wirksamste.*

Die Zahlen sind Schätzungen und sollen es sein. Der Wert der Rechnung liegt nicht in ihrer Genauigkeit, sondern darin, dass sie zwingt, Ertrag und Aufwand getrennt zu betrachten — und dabei fällt auf, welcher Hebel ungenutzt ist.

(c) Vertrauensgrenzen und Bedrohungen.
Der Datenfluss. Browser → Web → Anwendung → Datenbank, dazu ein Zahlungsdienst.

Grenze	Vertrauen?	Prüfung nötig
Browser → Web	**nein**	**alle Eingaben**
Web → Anwendung	teils	oft vergessen
Anwendung → DB	teils	Anfragen binden
Anwendung → Zahlung	nein	**Antwort prüfen**
Zahlung → Anwendung	**nein**	Signatur, nicht Rückleitung

Die letzte Zeile ist ein klassischer Fehler: Der Zahlungserfolg wird aus der Rückleitung des Browsers gelesen statt aus einer signierten Meldung des Dienstes. Damit bestimmt der Kunde, ob er bezahlt hat.

Die sechs Fragen an einer Grenze.

Bedrohung	Gefunden?	Befund
Vortäuschen	**ja**	**Sitzungskennung ratbar**
Verfälschen	ja	Betrag im Formular
Abstreiten	ja	keine Aufzeichnung
Preisgeben	nein	
Lahmlegen	ja	keine Begrenzung
Rechte ausweiten	nein	

Vier Funde an einer einzigen Grenze — und drei davon hätte man ohne die Liste nicht gesucht, weil man beim Wort „Sicherheit“ zuerst an Preisgeben denkt. Das ist der ganze Nutzen einer Gedächtnisstütze.

Das Modell veraltet schneller als das System

Was sich ändert	Neue Schnittstelle, neuer Zulieferer, neues Netz
Was bleibt	Das Diagramm von vor drei Jahren
Die Folge	**Vertrauensgrenzen, die es nicht mehr gibt**

Ein Bedrohungsmodell ist kein Dokument, sondern eine wiederkehrende Übung. Der praktikable Weg ist, es an Änderungen zu koppeln: Wer eine neue Schnittstelle einführt, zeichnet sie ein und stellt die sechs Fragen — eine Stunde, nicht ein Projekt.

Shostack[24] entwickelte die vier Fragen und die Bedrohungsliste; Bellovin[2] zeigt, wie man Angreifermodelle für konkrete Lagen bildet; Schneier[22] begründete früh, dass Sicherheit ein fortlaufender Vorgang und kein Erzeugnis ist.

3 Angriffsfläche und Vertrauensgrenzen

Was zur Angriffsfläche zählt

Eingänge	Alles, worüber Daten von außen hereinkommen
Rechte	Womit der Code läuft, wenn er hereingelassen hat
Daten	**Was ein Angreifer erbeuten kann**

Die drei Größen multiplizieren sich. Ein Eingang, der mit geringen Rechten läuft und auf wenig Daten zugreift, ist ein kleines Problem; derselbe Eingang mit Verwaltungsrechten auf dem Gesamtbestand ist ein Totalverlust. Angriffsfläche zu messen heißt, alle drei zu zählen.

Ein Maß.

$$A = \sum_{i} e_i \cdot r_i \cdot d_i$$

mit Eingangsgewicht e, Rechtestufe r und Datenumfang d.

Eingang	e	r	d	A_i
Anmeldeseite	3	1	1	3
Suchfunktion	2	2	3	12
Dateiupload	3	3	2	18
Verwaltung	1	**5**	**5**	**25**
Alte Schnittstelle	2	4	4	**32**
Summe				**90**

Die letzte Eingangszeile ist der größte Posten und der, an den niemand denkt — eine Schnittstelle aus einer früheren Fassung, die niemand mehr benutzt und die niemand abgeschaltet hat. Sie trägt ein Drittel der Fläche.

Die billigste Maßnahme

Maßnahme	Aufwand	Flächenwirkung
Alte Schnittstelle abschalten	4 h	−32 (36 %)
Verwaltung entrechten	12 h	−15
Upload absichern	40 h	−9
Suchfunktion härten	24 h	−6

Vier Stunden für sechsunddreißig Prozent — weil Abschalten die einzige Maßnahme ist, die eine Angriffsfläche auf null setzt statt sie zu verkleinern. Was es nicht gibt, kann nicht angegriffen werden, muss nicht gepflegt und nicht geprüft werden.

Vertrauensgrenzen

Definition	Eine Linie, über die Daten oder Steuerung wechseln und jenseits derer andere Annahmen gelten
Die Regel	**An jeder Grenze wird geprüft — ohne Ausnahme**
Der Fehler	Innen als Synonym für vertrauenswürdig

Die dritte Zeile ist die folgenreichste Fehlannahme des Fachs. Sie stammt aus einer Zeit, in der das Innennetz physisch abgeschlossen war. Heute genügt ein übernommener Arbeitsplatz, und der Angreifer steht innen — mit allen Vertrauensvorschüssen, die dort gelten.

Wo Grenzen verlaufen.

Grenze	Erkannt?	
Netzwerk außen/innen	immer	
Benutzer zu Anwendung	meist	
Anwendung zu Datenbank	teils	
Zwischen Diensten	selten	„intern“
Zu Fremdbibliotheken	**fast nie**	**Kapitel 8**
Prozess zu Betriebssystem	selten	

Die unteren drei Zeilen sind die ungesicherten. Eine Fremdbibliothek läuft mit denselben Rechten wie der eigene Code und wird nie als Grenze gedacht — obwohl sie von Fremden geschrieben wurde und sich mit jeder Aktualisierung ändert.

Das Prüfen an der falschen Stelle

Ort	Wirksam?	
Im Browser	nein	**Angreifer umgeht ihn**
Am Eingang des Dienstes	ja	
Kurz vor der Verwendung	**ja**	am sichersten

Eine Prüfung im Browser ist eine Bedienhilfe, keine Sicherung — sie verhindert Tippfehler und nichts sonst. Die dritte Zeile ist die zuverlässigste, weil dazwischen keine weitere Umwandlung mehr stattfindet, die die Prüfung entwerten könnte.

Der häufigste Fehler ist die Prüfung an einer *Stelle mit anschließendem Vertrauen. Das verletzt Saltzers Grundsatz der vollständigen Prüfung: Geprüft wird bei jedem Zugriff, nicht beim ersten.*

Aufgabe 3.1.

(a) Bestimmen Sie die Angriffsfläche eines gewachsenen Systems.
(b) Rechnen Sie die Wirkung von Segmentierung aus.
(c) Untersuchen Sie, was das Vertrauen ins Innennetz kostet.

Lösung Schritt für Schritt.

(a) Angriffsfläche eines gewachsenen Systems.
Die Bestandsaufnahme. Zwölf Jahre Laufzeit.

Art	Anzahl	davon genutzt	Anteil
Endpunkte	340	210	62 %
Datenbankkonten	18	6	33 %
Dienstkonten	24	**11**	**46** %
Offene Netzdienste	31	14	45 %
Bibliotheken	412	≈ 180	**44** %

Über die Hälfte von allem wird nicht mehr benutzt und ist weiterhin erreichbar. Das ist kein Sonderfall, sondern der Normalzustand gewachsener Systeme: Hinzufügen ist einfach, Entfernen verlangt die Gewissheit, dass es niemand mehr braucht — und die hat niemand.

Die Aufräumrechnung.

Schritt	Aufwand	Fläche	Rest
Ausgangslage	—	100 %	
Nutzung messen	24 h	100 %	
Ungenutztes sperren	16 h	**58** %	
Sechs Wochen beobachten	8 h	**54** %	3 Rückmeldungen
Endgültig entfernen	12 h	54 %	
Summe	**60 h**	**−46 %**	

Der entscheidende Schritt ist das Sperren mit Beobachtung statt des sofortigen Löschens: Man erfährt in sechs Wochen, was doch gebraucht wird, ohne etwas unwiederbringlich zu entfernen. Drei Rückmeldungen bei hundertdreißig gesperrten Endpunkten sind der übliche Befund.

(b) Die Wirkung von Segmentierung.
Die Lage. Ein Arbeitsplatz ist übernommen. Wie viel ist erreichbar?

Aufbau	Erreichbar	Weitere Hürden	Anteil
Flaches Netz	**alles**	0	**100** %
3 Segmente	ein Drittel	1	33 %
8 Segmente	ein Achtel	1	12 %
8 + Rechteschnitt	**ein Achtel, lesend**	2	**4** %

Der Sprung von der ersten zur zweiten Zeile ist der größte und der billigste. Von dort ab flacht der Gewinn ab, und der Verwaltungsaufwand steigt — acht Segmente sind für die meisten Häuser die vernünftige Obergrenze.

Der Preis.

Segmente	Einrichtung	Pflege/Jahr	Störungen
3	80 h	20 h	wenige
8	200 h	60 h	spürbar
20	600 h	**240** h	**ständig**

Die letzte Zeile ist der Punkt, an dem Saltzers achter Grundsatz zuschlägt: Bei zwanzig Segmenten wird so oft eine Ausnahme gebraucht, dass die Ausnahmen zur Regel werden — und dann sind es faktisch wieder drei.

(c) Was das Vertrauen ins Innennetz kostet.
Der Vergleich zweier Haltungen.

	Innen vertraut	Nichts vertraut
Anmeldung zwischen Diensten	keine	immer
Verschlüsselung intern	nein	ja
Aufwand	gering	hoch
Bei übernommenem Platz	**alles offen**	**eine Hürde mehr**

Die Schadensrechnung.

Größe	Wert	
Wahrschein-lichkeit je Jahr	0,12	ein Platz übernommen
Schaden bei flachem Netz	900 000	
Erwartungswert	**108 000**	
Schaden bei Segmentierung	180 000	
Erwartungswert	**21 600**	
Ersparnis je Jahr	**86 400**	gegen 60 h Pflege

Die Zahlen sind Schätzungen, und die Rechnung trägt trotzdem: Selbst wenn man die Wahrscheinlichkeit um den Faktor fünf zu hoch angesetzt hat, bleibt die Segmentierung wirtschaftlich. Das ist die Prüfung, die eine Risikorechnung leisten soll — nicht Genauigkeit, sondern Robustheit gegen die eigene Unsicherheit.

Die Angriffsfläche wächst von allein

Vorgang	Häufigkeit	Richtung
Neue Schnittstelle	oft	+
Neue Bibliothek	sehr oft	+
Neuer Zulieferer	regelmäßig	+
Abschalten	**selten**	−

Ohne bewusste Gegenarbeit wächst die Fläche monoton — das ist Lehmans zweites Gesetz aus Band 17, hier für die Sicherheit. Und wie dort lautet die Abhilfe nicht „einmal aufräumen“, sondern: bei jeder Erweiterung eine Frage nach dem, was dafür wegfallen kann.

Saltzer und Schroeder[21] begründeten die geringsten Rechte und die vollständige Prüfung; Lampson[12] führte die Zugriffsmatrix ein, aus der die Rechtestufen stammen; Anderson[1] zeigt an Fallbeispielen, wie Vertrauensgrenzen in der Praxis verlaufen.

Part II

Wo Systeme brechen

4 Speicherfehler

Die größte Fehlerklasse

Erhebung	Anteil	Gegenstand
Großer Betriebssystemhersteller	≈ 70 %	schwere Lücken
Browserhersteller	≈ 70 %	
Mobiles Betriebssystem	≈ 65 %	
Übergreifend	**≈ 60–70 %**	**systemnahe Software**

Mehrere große Hersteller haben unabhängig voneinander denselben Anteil gefunden. Das ist für dieses Fach eine ungewöhnlich gute Datenlage — und die Zahl hat sich über zwanzig Jahre kaum verändert, trotz erheblicher Anstrengungen.

Die Unterarten.

Art	Ursache	Wirkung
Überlauf	**Länge nicht geprüft**	fremder Speicher überschrieben
Zugriff nach Freigabe	Verweis überlebt	**fremde Daten**
Doppelte Freigabe	zweimal aufgeräumt	Verwaltungsdaten kaputt
Bereichsüberschreitung	Index falsch	Lesen fremder Daten
Ganzzahlüberlauf	**Rechnung kippt**	Länge wird negativ

Die letzte Zeile ist die tückischste, weil sie kein Speicherfehler ist, *sondern einen erzeugt: Eine Längenberechnung läuft über, das Ergebnis wird klein oder negativ, und die anschließende Prüfung geht durch. Der eigentliche Fehler liegt eine Anweisung früher als der Absturz.*

Warum die Prüfung so oft fehlt

Die Sprache	Trennt Zeiger und Länge; nichts erzwingt ihren Zusammenhang
Die Schnittstelle	**Länge und Puffer sind zwei Argumente — man kann sie widersprüchlich übergeben**
Der Mensch	Prüft an 99 Stellen und vergisst die hundertste

Die dritte Zeile ist keine Nachlässigkeit, sondern die Fehlerrate menschlicher Arbeit — Band 17 beziffert sie. Bei einer Million Zeilen genügt eine Fehlerrate von einem Promille für tausend Gelegenheiten. Die Abhilfe liegt deshalb nicht in mehr Sorgfalt, sondern in der zweiten Zeile.

Die Gegenmaßnahmen und was sie leisten

Maßnahme	Verhindert	Kosten
Zufällige Adresslage	erschwert	gering
Kein ausführbarer Datenbereich	erschwert	gering
Kellerwächter	teilweise	≈ 2 %
Grenzprüfung zur Laufzeit	**ja**	5–20 %
Sprache mit Speichersicherheit	**ja**	**keine Laufzeitkosten**

Die ersten drei Zeilen erschweren die Ausnutzung, ohne den Fehler zu beseitigen — sie erhöhen den Aufwand des Angreifers, und jede von ihnen wurde nach ihrer Einführung umgangen. Nur die letzten beiden schließen die Klasse.

Die letzte Zeile ist der stärkste bekannte Fall für eine Entwurfsentscheidung mit Sicherheitswirkung. Was der Übersetzer prüft, kann zur Laufzeit nicht schiefgehen und kostet dort auch nichts — Band 17, Kapitel 8, in seiner folgenreichsten Anwendung.

Umschreiben ist kein Plan

Vorgehen	Aufwand	Wirkung
Alles umschreiben	Jahrzehnte	vollständig
Neues in sicherer Sprache	keiner	**hoch**
Grenzen zuerst	mittel	hoch

Die mittlere Zeile ist der praktikable Weg und beruht auf einer Beobachtung: Neue Lücken sitzen weit überwiegend in neuem Code. Wer nur Neues in einer sicheren Sprache schreibt, senkt die Rate neuer Speicherlücken binnen weniger Jahre erheblich — ohne eine einzige alte Zeile anzufassen.

Das ist zugleich die Antwort auf Band 17, Kapitel 14: Die vollständige Neuentwicklung scheitert, die schrittweise Ablösung an der Grenze wirkt.

Aufgabe 4.1.

(a) Verfolgen Sie einen Ganzzahlüberlauf.
(b) Rechnen Sie die Wirkung der Sprachwahl aus.
(c) Bestimmen Sie den Wert der erschwerenden Maßnahmen.

Lösung Schritt für Schritt.

(a) Ein Ganzzahlüberlauf.
Der Code. Ein Puffer für n Einträge zu je 32 Byte.

```
groesse = n * 32
if groesse > MAXPUFFER: fehler()
p = reserviere(groesse)
fuer i in 0..n-1:  schreibe(p, i, 32)
```

Bei 32-bit-Arithmetik.

n	$n \cdot 32$ **exakt**	**gerechnet**	**Prüfung**
1000	32 000	32 000	greift
10^6	$3{,}2 \cdot 10^7$	$3{,}2 \cdot 10^7$	greift
134 217 728	$\mathbf{2^{32}}$	**0**	**geht durch**
134 217 729	$2^{32} + 32$	32	geht durch

Bei $n = 2^{27}$ wird die Größe zu null. Es werden null Byte reserviert, die Prüfung ist zufrieden, und anschließend schreibt die Schleife 134 Millionen mal 32 Byte in einen Puffer der Länge null. Der Fehler steht in Zeile eins, der Absturz in Zeile vier.

Die drei Abhilfen.

Abhilfe	**Wirksam?**	
Vor der Multiplikation prüfen	ja	$n >$ MAX/32
Breitere Ganzzahlen	verschiebt	nur die Grenze
Überlaufprüfende Arithmetik	**ja**	**Sprachmittel**

Die zweite Zeile ist die verbreitetste und die schwächste: Sie schiebt das Problem zu größeren n, ohne es zu beseitigen. Die dritte ist wieder die strukturelle Antwort — die Sprache lässt die stille Umlaufrechnung gar nicht zu.

(b) Die Wirkung der Sprachwahl.
Die Lage. Ein System, 800 000 Zeilen, 60 000 neue Zeilen im Jahr.

Jahr	Alt (unsicher)	Neu (sicher)	Neue Lücken
0	800	0	**24**
2	800	120	21
5	800	300	17
10	800	600	**11**

(Zeilen in Tausend; Lückenrate der Altbestände sinkt, weil er nicht mehr wächst)

> *Von vierundzwanzig auf elf neue Speicherlücken im Jahr, ohne eine alte Zeile anzufassen. Der Grund ist, dass neue Lücken überwiegend in neuem Code entstehen — alter Code ist durch Jahre der Nutzung bereits abgeklopft.*

Der Vergleich der Wege.

Weg	Aufwand	Nach 5 J.	Nach 10 J.
Nichts tun	0	24	24
Alles umschreiben	≈ 200 PJ	24	≈ 2
Neues sicher	≈ 3 PJ	**17**	**11**
Neues sicher + Grenzen	≈ 12 PJ	**12**	**6**

Die vollständige Neufassung wirkt am stärksten und ist bei zweihundert Personenjahren kein realer Vorschlag. Die letzte Zeile — neues sicher plus die Bestandteile an der Vertrauensgrenze — bringt die halbe Wirkung für sechs Prozent des Aufwands.

(c) Der Wert der erschwerenden Maßnahmen.
Was ein Angriff durchlaufen muss.

Schutz	ohne	mit	Aufwands-faktor
Zufällige Adresslage	1	$\approx 2^{16}$ Versuche	$\times$**50**
Kein ausführbarer Datenbereich	1	Umweg nötig	$\times$8
Kellerwächter	1	anderer Weg	$\times$4
Alle drei			$\approx$ $\times$**1600**

Faktor sechzehnhundert klingt nach Sicherheit und ist es nicht: Er verschiebt den Aufwand für einen Angreifer von Tagen auf Monate. Gegen einen Gelegenheitstäter genügt das; gegen einen entschlossenen Angreifer ist es eine Verzögerung, kein Hindernis.

Die ehrliche Bilanz.

Art	Wirkung	
Erschwerende Maßnahmen	**Aufwand** $\times$	umgehbar
Grenzprüfung	**Klasse geschlossen**	Laufzeitkosten
Sichere Sprache	**Klasse geschlossen**	keine

Der Unterschied zwischen den Zeilen ist grundsätzlich: Die erste multipliziert den Angreiferaufwand, die anderen beiden setzen die Erfolgswahrscheinlichkeit auf null. Ein Faktor lässt sich durch mehr Aufwand überwinden, eine Null nicht.

Warum die Klasse nicht verschwindet

Bestand	Milliarden Zeilen in unsicheren Sprachen, produktiv im Einsatz
Nachwuchs	Systemnahe Arbeit wird weiterhin so geschrieben
Schnittstellen	**Sichere Sprachen rufen unsichere Bibliotheken auf**

Die dritte Zeile wird gern übersehen: Ein Programm in einer speichersicheren Sprache, das eine unsichere Bibliothek einbindet, hat die Sicherheit an dieser Grenze verloren. Die Garantie endet dort, wo die Sprache endet — und genau dort verläuft eine Vertrauensgrenze im Sinne von Kapitel 3.

Dowd und Mitautoren[6] behandeln die Fehlerklassen systematisch aus der Sicht der Prüfung; Howard und LeBlanc[8] zeigen, wie man sie beim Schreiben vermeidet; die CWE-Liste[16] führt sie in ihrer aktuellen Häufigkeit.

5 Eingaben und Einschleusung

Ein Muster, viele Namen

Zielsprache	Name	Folge
Datenbank-abfrage	SQL-Einschleusung	**Daten lesen, ändern**
Seiteninhalt	Skript-einschleusung	Sitzung übernehmen
Betriebssystem	Befehls-einschleusung	**alles**
Verzeichnispfad	Pfadausbruch	fremde Dateien
Vorlagensprache	Vorlagen-einschleusung	Code ausführen

Fünf Namen, ein Muster: Daten aus fremder Hand werden mit Anweisungen vermischt, und der Empfänger kann beide nicht mehr unterscheiden. Wer das Muster kennt, erkennt auch die sechste Erscheinungsform, die noch keinen Namen hat.

Die Ursache in einem Satz.

Das Problem	Eine Zeichenkette wird zusammengebaut, in der Daten und Anweisungen nebeneinanderstehen
Der Empfänger	Sieht nur die fertige Kette und muss raten, was was ist
Die Lösung	**Daten und Anweisung getrennt übergeben — nie verketten**

Das ist dieselbe Trennung wie bei Jacquards Webstuhl in Band 16: Maschine und Anweisung auseinanderhalten. Wo sie verschmelzen, bestimmt derjenige die Anweisung, der die Daten liefert.

Warum Maskieren die schwächere Antwort ist

	Maskieren	Gebundene Parameter
Wirkt	wenn richtig gemacht	**immer**
Hängt ab von	**Zeichensatz, Zielsprache**	nichts
Vergessbar	**an jeder Stelle**	fällt auf
Mehrfach angewandt	erzeugt Fehler	unkritisch

Maskieren verlangt, an jeder einzelnen Stelle das Richtige zu tun — und die Fehlerrate menschlicher Arbeit sorgt dafür, dass eine Stelle vergessen wird. Gebundene Parameter verlagern die Trennung in die Schnittstelle: Der Fehler ist dann nicht mehr möglich, statt nur unwahrscheinlich.

Prüfen, was hereinkommt

Ansatz	Bewertung	
Weiße Liste	**gut**	**nur Erlaubtes durch**
Schwarze Liste	schlecht	man vergisst Fälle
Länge begrenzen	ergänzend	
Typ erzwingen	**sehr gut**	Band 17, Kap. 8

Die zweite Zeile ist Saltzers Grundhaltung in ihrer praktischen Form: Wer aufzählt, was verboten ist, hat immer etwas vergessen — und der Angreifer sucht genau danach. Wer aufzählt, was erlaubt ist, irrt sich zu seinen eigenen Lasten und merkt es beim ersten legitimen Fall.

Prüfen ersetzt kein Trennen

Maßnahme	Gegen Einschleusung	
Eingabeprüfung	hilft	nicht ausreichend
Gebundene Parameter	**löst**	
Beides	**richtig**	**Stufung**

Eingabeprüfung ist eine fachliche Aufgabe — ein Datum soll ein Datum sein — und keine Sicherungsmaßnahme. Wer sie als solche einsetzt, muss alle Zielsprachen kennen, in die der Wert je gelangen könnte. Das kann er nicht wissen; also trennt er stattdessen an der Stelle der Verwendung.

Aufgabe 5.1.

(a) Verfolgen Sie, wo eine Verkettung entsteht.
(b) Rechnen Sie die Restwahrscheinlichkeit bei Maskierung aus.
(c) Bestimmen Sie die Kosten der Umstellung.

Lösung Schritt für Schritt.

(a) Wo eine Verkettung entsteht.
Die Bestandsaufnahme. Ein System mit 340 Datenbankzugriffen.

Art des Zugriffs	Anzahl	gebunden	Risiko
Über Abbildungsschicht	268	ja	gering
Handgeschrieben, gebunden	51	ja	gering
Handgeschrieben, verkettet	**17**	**nein**	**hoch**
Dynamischer Tabellenname	4	unmöglich	hoch

Fünf Prozent der Zugriffe tragen das gesamte Risiko — und sie sind maschinell auffindbar, weil sie ein erkennbares Muster haben: Zeichenkettenverkettung in der Nähe eines Abfragebefehls. Eine Suche über den Bestand findet sie in Minuten.

Die letzte Zeile im Detail.

Das Problem	Tabellen- und Spaltennamen lassen sich nicht binden
Der falsche Weg	Maskieren und hoffen
Der richtige	**Weiße Liste erlaubter Namen, Eingabe wird zugeordnet**

Hier ist die weiße Liste nicht die schwächere, sondern die einzige Antwort — weil die Bindung an dieser Stelle technisch nicht zur Verfügung steht. Der Benutzerwert wählt dann aus einer festen Menge aus, statt in die Abfrage zu gelangen.

(b) Restwahrscheinlichkeit bei Maskierung.
Das Modell. Bei n Stellen und einer Fehlerrate f je Stelle:

$$P(\text{mindestens eine Lücke}) = 1 - (1 - f)^{n}.$$

n	$f = 0{,}02$	$f = 0{,}005$	$f = 0{,}001$
20	0,33	0,10	0,02
100	0,87	0,39	0,10
340	**0,999**	**0,82**	0,29
1000	≈ 1	0,99	**0,63**

Bei dreihundertvierzig Stellen und einer Fehlerrate von einem Promille — einer sehr guten Rate — liegt die Wahrscheinlichkeit einer Lücke bei neunundzwanzig Prozent. Sorgfalt allein reicht nicht, weil die Zahl der Gelegenheiten die Sorgfalt schlägt.

Der Vergleich mit Bindung.

Ansatz	P (Lücke)	
Maskieren, $f = 0{,}001$	0,29	
Bindung, Verkettung sichtbar	≈ **0,01**	maschinell prüfbar
Bindung + Prüfung im Bau	≈ **0,001**	**Verkettung wird abgelehnt**

Der Sprung von der ersten zur zweiten Zeile stammt nicht daher, dass Menschen sorgfältiger würden, sondern daher, dass der Fehler nun ein sichtbares Muster hat. Was maschinell gefunden werden kann, muss nicht erinnert werden — Band 18, Kapitel 2, in sicherheitstechnischer Anwendung.

(c) Die Kosten der Umstellung.

Schritt	Aufwand	Wirkung	Rang
Verkettungen suchen	4 h	—	
17 Stellen umstellen	34 h	hoch	**1**
4 Namen auf weiße Liste	12 h	hoch	2
Prüfung im Bau verankern	16 h	**dauerhaft**	**3**
Summe	**66 h**		

Sechsundsechzig Stunden für eine Fehlerklasse, die seit fünfundzwanzig Jahren die Listen anführt. Der vierte Schritt ist der wichtigste, weil er verhindert, dass die Klasse zurückkommt — ohne ihn ist die Arbeit in drei Jahren wieder zu tun.

Warum es trotzdem selten geschieht.

Kein Leidensdruck	Solange nichts passiert, ist die Lücke unsichtbar
Keine Zuständigkeit	Sicherheit gehört keinem Team
Der Nutzen fällt nicht an	**Erfolg heißt, dass nichts geschieht**

Die dritte Zeile ist das Grundproblem dieses Fachs: Eine gelungene Absicherung ist an nichts erkennbar. Wer sie durchsetzen will, muss den erwarteten Schaden beziffern — die Rechnung aus Kapitel 2 — weil es keine sichtbare Wirkung gibt, auf die man zeigen könnte.

Die Liste ändert sich kaum

Jahr	Auf Platz eins	
2003	Einschleusung	
2010	Einschleusung	
2017	Einschleusung	
2021	Rechteprüfung	**Einschleusung auf** 3
2025	Rechteprüfung	Einschleusung weiter oben

Über zwei Jahrzehnte stehen dieselben zwei Klassen an der Spitze. Das ist kein Erkenntnisproblem — die Abhilfen sind bekannt, billig und in jeder Bibliothek vorhanden. Es ist ein Umsetzungsproblem, und damit steht dieses Kapitel in derselben Reihe wie Band 17.

Die OWASP-Liste[18] führt die Klasse seit über zwanzig Jahren; Stuttard und Pinto[25] behandeln die Erscheinungsformen im Web systematisch; die CWE-Liste[16] ordnet sie nach gemeldeter Häufigkeit.

6 Rechte und Identität

Zwei Fragen, die verwechselt werden

	Wer bist du?	Was darfst du?
Prüft	**Identität**	**Befugnis**
Ergebnis	ein Name	eine Erlaubnis
Wann	einmal je Sitzung	**bei jedem Zugriff**
Fehlt oft	selten	**häufig**

Die dritte Zeile ist Saltzers Grundsatz der vollständigen Prüfung. Wer beim Anmelden prüft und danach vertraut, hat eine Sitzung abgesichert und keinen Zugriff. Die vierte Zeile erklärt, warum die Befugnisprüfung heute an der Spitze der Fehlerlisten steht: Sie muss überall stehen und wird an einzelnen Stellen vergessen.

Der häufigste Fehler.

Das Muster	Die Kennung des Objekts kommt aus der Anfrage
Was geprüft wird	Ob der Benutzer angemeldet ist
Was nicht geprüft wird	**Ob dieses Objekt ihm gehört**
Die Folge	Kennung ändern und fremde Daten sehen

Dieser Fehler braucht keine Werkzeuge und kein Wissen — er wird durch Ändern einer Zahl in der Adresszeile gefunden. Genau deshalb ist er so häufig entdeckt und so folgenreich: Er ist der einzige Angriff, den ein zufälliger Benutzer aus Versehen ausführt.

Wo die Befugnisprüfung hingehört

Ort	Vergessbar?	
In jeder Funktion	**ja**	*n* Gelegenheiten
In einer Zwischenschicht	teils	pro Pfad
In der Datenzugriffsschicht	**kaum**	**eine Stelle**

Wenn jede Abfrage von vornherein nur die Daten des angemeldeten Benutzers liefern kann, ist die Vergesslichkeit ausgeschaltet — das Vergessen der Prüfung führt dann nicht zu fremden Daten, sondern zu einem leeren Ergebnis. Dasselbe Muster wie bei den gebundenen Parametern: den Fehler unmöglich machen statt ihn zu vermeiden.

Passwörter

Verbreitete Regel	Wirkung	Heutige Empfehlung
Regelmäßiger Wechsel	**schädlich**	nur bei Verdacht
Zeichenklassen erzwingen	gering	**Länge stattdessen**
Mindestlänge 8	zu kurz	≥ 12
Gegen Sperrliste prüfen	**hoch**	ja
Hinweisfragen	schädlich	abschaffen

Die erste Zeile ist die bekannteste Kehrtwende des Fachs. Erzwungener Wechsel führt zu vorhersagbaren Abwandlungen — aus `Sommer2024!` wird `Sommer2025!` — und senkt die Sicherheit, statt sie zu erhöhen. Die Empfehlung wurde 2017 geändert; die Vorschriften vieler Häuser nicht.

Was tatsächlich wirkt.

Maßnahme	Wirkung	
Zweiter Faktor	**sehr hoch**	**schlägt alles andere**
Langsame Ableitung	hoch	bei Diebstahl der Datei
Versuchs-begrenzung	hoch	gegen Durchprobieren
Sperrlistenprüfung	hoch	gegen Wiederverwen-dung

Die erste Zeile wirkt gegen alle Angreiferklassen aus Kapitel 2 und macht gestohlene Passwörter allein wertlos. Sie ist die einzelne Maßnahme mit dem besten Verhältnis von Aufwand zu Wirkung, die dieser Band kennt.

Die Wiederverwendung ist das eigentliche Problem

Befund	Größenordnung
Konten je Person	Dutzende bis über hundert
Verschiedene Passwörter	**eine Handvoll**
Folge	ein Einbruch öffnet viele Konten

Die Zahlen streuen zwischen Erhebungen erheblich, die Richtung ist eindeutig: Menschen können sich keine hundert verschiedenen Geheimnisse merken — das ist die Gedächtnisgrenze aus Band 18, Kapitel 2, und keine Nachlässigkeit. Wer Wiederverwendung beklagt, verlangt etwas biologisch Unmögliches.

Die Abhilfe liegt deshalb nicht bei den Benutzern, sondern im Entwurf: Passwortverwalter, zweite Faktoren und passwortlose Verfahren nehmen die Last vom Gedächtnis. Saltzers achter Grundsatz — was zu umständlich ist, wird umgangen — gilt auch für Merkleistungen.

Aufgabe 6.1.

(a) Rechnen Sie Passwortstärke gegen Rechenleistung.
(b) Bestimmen Sie die Wirkung des zweiten Faktors.
(c) Prüfen Sie ein Rechtemodell auf Lücken.

Lösung Schritt für Schritt.

(a) Passwortstärke gegen Rechenleistung.
Die Entropie. Bei z möglichen Zeichen und Länge l:

$$H = l \cdot \log_2 z \quad \text{bit}.$$

Art	z	l	H **(bit)**
Nur Kleinbuchstaben	26	8	37,6
Mit Ziffern	36	8	41,4
Alle Zeichen	95	8	52,6
Alle Zeichen	95	12	**78,8**
Vier zufällige Wörter	7776	4	**51,7**
Sechs Wörter	7776	6	77,5

Vier zufällige Wörter aus einer Liste von 7776 ergeben ungefähr so viel Entropie wie acht zufällige Zeichen aus dem vollen Vorrat — und sind ungleich leichter zu merken. Das ist der stärkste Einwand gegen Zeichenklassenvorschriften.

Die Zeit zum Durchprobieren.

H	**schnelle Prüfsumme**	**langsame Ableitung**	**Faktor**
40	$\approx$ 2 min	$\approx$ 4 Monate	10^5
52	6 Tage	$\approx$ 1600 J.	
60	4 Jahre	$> 10^5$ J.	
78	10^6 J.	unerreichbar	

(bei 10^{11} *Versuchen je Sekunde gegen eine schnelle Prüfsumme,* 10^6 *gegen eine langsame Ableitung)*

Die zweite Spalte zeigt, warum die Wahl der Ableitungsfunktion wichtiger ist als die Passwortregeln: Sie verschiebt die Grenze um fünf Größenordnungen. Ein mäßiges Passwort hinter einer langsamen Ableitung hält länger als ein gutes hinter einer schnellen.

(b) Die Wirkung des zweiten Faktors.

Angriff	ohne	mit	Wirkung
Gestohlene Liste	Konto offen	wertlos	voll
Wiederverwendetes Passwort	Konto offen	wertlos	voll
Durchprobieren	möglich	wertlos	voll
Täuschungsseite, Code	offen	Zeitfenster	teilweise
Täuschungsseite, Sicherheitsschlüssel	offen	**wertlos**	**voll**

Die letzten beiden Zeilen unterscheiden die Verfahren. Ein Einmalcode kann weitergeleitet werden — der Angreifer fragt ihn ab und benutzt ihn sofort. Ein Sicherheitsschlüssel bindet die Anmeldung an die Adresse der echten Seite und ist damit gegen Täuschung unempfindlich.

Die Rechnung über eine Belegschaft.

Größe	Wert	
Beschäftigte	200	
Erfolgreiche Täuschung/Jahr	≈ 6	ohne zweiten Faktor
Davon zu Übernahme	≈ 4	
Mit Einmalcodes	$\approx 1{,}2$	$-70\,\%$
Mit Schlüsseln	$\approx \mathbf{0}$	**Klasse geschlossen**

Wieder der Unterschied zwischen einem Faktor und einer Null. Codes senken die Rate; Schlüssel beseitigen den Angriffsweg, weil das Verfahren die Seitenadresse mitprüft und ein Angreifer sie nicht fälschen kann.

(c) Ein Rechtemodell prüfen.
Die Systematik. Für jede Kombination aus Rolle und Vorgang eine Zelle.

Vorgang	Gast	Nutzer	Leiter	Verw.
Eigenes lesen	–	+	+	+
Fremdes lesen	–	–	+	+
Eigenes ändern	–	+	+	+
Fremdes ändern	–	**?**	+	+
Bericht ausgeben	–	–	+	+
Rechte vergeben	–	–	**?**	+

Die beiden Fragezeichen sind der Ertrag der Übung: Zwei Zellen, über die nie jemand entschieden hat, weil sie im Alltag nicht vorkommen. Genau dort ist das Verhalten des Systems zufällig — es tut, was der Code eben tut, nicht, was gewollt ist.

Die Prüfung der Fragezeichen.

Zelle	Tatsächlich	Gewollt
Nutzer ändert Fremdes	**erlaubt**	verboten
Leiter vergibt Rechte	erlaubt	eingeschränkt

Beide Zellen waren offen — das ist Saltzers zweiter Grundsatz in seiner Verletzung: Was nicht ausdrücklich verboten wurde, war erlaubt. Eine Matrix mit sechs mal vier Feldern findet solche Lücken in einer Stunde und ohne jedes Werkzeug.

Rollen wachsen, Rechte bleiben

Vorgang	Häufigkeit	Richtung
Neue Aufgabe, Recht dazu	oft	+
Abteilungswechsel	regelmäßig	+
Recht wieder entziehen	**selten**	−

Nach zehn Jahren im Haus hat eine Person die Rechte aller Stellen, die sie je innehatte. Das ist die Angriffsflächenkurve aus Kapitel 3, angewandt auf Menschen — und der Grund, warum ein Innentäter meist mehr kann, als seine Stelle erfordert.

Die Abhilfe ist dieselbe: eine wiederkehrende Überprüfung, gekoppelt an ein Ereignis, das ohnehin stattfindet — den Wechsel der Stelle. Wer Rechte beim Wechsel neu vergibt statt zu ergänzen, hat das Problem strukturell gelöst.

Saltzer und Schroeder[21] begründeten die geringsten Rechte und die vollständige Prüfung; Lampson[12] lieferte mit der Zugriffsmatrix das Werkzeug für Teil (c); die NIST-Richtlinie[17] vollzog 2017 die Kehrtwende bei den Passwortregeln.

Part III

Das Umfeld

7 Konfiguration und Voreinstellungen

Die Voreinstellung ist die Entscheidung

Einstellung	Wird geändert von	
Voreinstellung	≈ 5–10 %	**der Rest bleibt**
Beim ersten Start abgefragt	100 %	jemand entscheidet
Im Handbuch beschrieben	< 1 %	

Wer eine Voreinstellung wählt, entscheidet für neunzig Prozent aller Installationen. Das ist keine Bequemlichkeit der Anwender, sondern die Trägheit, die jede Voreinstellung hat — und sie gilt auch für sorgfältige Fachleute unter Zeitdruck.

Die Regel, die daraus folgt.

Sicher als Grundzustand	Das System ist nach der Installation geschlossen
Öffnen ist eine Handlung	**Wer aufmacht, tut es bewusst**
Kein Betrieb ohne Änderung	Standardkennwörter erzwingen eine Änderung

Die dritte Zeile ist die einzige, die zuverlässig wirkt: Ein System, das ohne gesetztes Kennwort nicht startet, hat keine Standardkennwörter im Feld. Alles andere — Hinweise, Warnungen, Handbuchtexte — wird von der Trägheit geschlagen.

Die häufigsten Fehlkonfigurationen

Fehler	Häufigkeit	Behebung
Verwaltungs-zugang offen erreichbar	hoch	Minuten
Standardkennwort belassen	hoch	Minuten
Ablageeimer öffentlich lesbar	**sehr hoch**	Minuten
Fehlerausgaben im Betrieb	hoch	Minuten
Prüfmodus aktiv gelassen	mittel	Minuten

Die letzte Spalte ist bemerkenswert: Jede dieser Fehlkonfigurationen ist in Minuten behoben. Sie tragen trotzdem einen erheblichen Teil der Vorfälle — weil niemand nachsieht. Der Aufwand liegt nicht im Beheben, sondern im Finden.

Geheimnisse im Quelltext

Ort	Sichtbar für	Entfernbar?
Quelltext	alle mit Lesezugriff	**nein — Historie**
Konfigurations-datei	Betrieb	ja
Umgebungs-variable	Prozess	teils sichtbar
Geheimnis-verwaltung	**nur bei Bedarf**	ja, mit Wechsel

Die erste Zeile enthält die Falle: Ein Geheimnis, das je in die Versionsverwaltung geraten ist, bleibt dort. Es aus dem aktuellen Stand zu löschen genügt nicht — die Historie behält es, und genau darauf zielen automatische Suchläufe.

Die einzige richtige Reaktion ist deshalb nicht das Entfernen, sondern der Wechsel: Das Geheimnis gilt als offengelegt und wird ersetzt. Alles andere ist Kosmetik.

Die Bequemlichkeitsfalle

Situation	Kurzfristig	Dauerhaft
„Erstmal alle Rechte, dann eingrenzen“	es läuft	**bleibt so**
„Prüfung abschalten zum Testen“	schneller	bleibt so
„Von überall erreichbar, vorläufig“	einfacher	bleibt so

Alle drei sind vernünftige Zwischenschritte und werden zum Dauerzustand, weil das Zurücknehmen keinen sichtbaren Nutzen hat. Es ist die technische Schuld aus Band 17, Kapitel 13 — mit dem Unterschied, dass die Zinsen hier nicht in Zeit anfallen, sondern in Risiko.

Die praktikable Abhilfe ist dieselbe wie dort: ein Termin. Eine Lockerung mit Ablaufdatum, die von selbst zurückfällt, wird zurückgenommen; eine ohne bleibt.

Aufgabe 7.1.

(a) Rechnen Sie die Wirkung sicherer Voreinstellungen aus.
(b) Bestimmen Sie den Wert regelmäßiger Prüfung.
(c) Untersuchen Sie die Ausbreitung einer Fehlkonfiguration.

Lösung Schritt für Schritt.

(a) Wirkung sicherer Voreinstellungen.
Die Lage. Eine Software mit 4000 Installationen.

Voreinstellung	geändert	unsicher	Anteil
Offen	8 %	**3680**	**92** %
Geschlossen	12 %	480	12 %
Erzwungene Wahl	100 %	≈ 200	5 %

Eine einzige Entscheidung des Herstellers verändert die Lage von zweiundneunzig auf zwölf Prozent — ohne dass ein einziger Betreiber etwas anders macht. Das ist die größte Hebelwirkung, die dieser Band kennt, und sie kostet nichts außer dem Entschluss.

Der Einwand und seine Prüfung.

Einwand	Gewicht	
„Kunden beschweren sich“	real	**einmal je Installation**
„Erhöht Supportaufwand“	real	≈ 8 min je Fall
„Wettbewerber ist einfacher“	real	
Gegenüber	3200 **offene Installationen**	

Die Einwände sind berechtigt und werden von der letzten Zeile geschlagen. Bei achttausend Minuten Mehraufwand für den Kundendienst gegen dreitausendzweihundert offene Anlagen ist die Rechnung eindeutig — sie wird nur selten aufgemacht, weil der Aufwand beim Hersteller anfällt und der Schaden beim Kunden.

(b) Der Wert regelmäßiger Prüfung.
Die Lage. 120 Systeme, Konfigurationsabweichungen entstehen laufend.

Prüfabstand	Mittlere Offenzeit	Erwartete Vorfälle	Aufwand
Nie	∞	**4,8**/J.	0
Jährlich	6 Monate	2,4	16 h
Vierteljährlich	6 Wochen	0,55	64 h
Monatlich	2 Wochen	0,18	190 h
Fortlaufend	**Stunden**	**0,02**	**40 h**

(fortlaufend: einmalige Einrichtung 120 *h, danach* 40 *h Pflege im Jahr)*

> *Die letzte Zeile ist zugleich die wirksamste und die billigste — weil maschinelle Prüfung nicht mit der Zahl der Systeme skaliert. Der Sprung von monatlich auf fortlaufend senkt Aufwand* und *Risiko; das ist selten und deshalb bemerkenswert.*

(c) Ausbreitung einer Fehlkonfiguration.
Der Weg. Eine Vorlage wird kopiert.

Jahr	Systeme	mit Fehler	Anteil
0	1	1	100 %
1	6	6	100 %
3	28	26	93 %
5	61	**54**	**89** %

> *Eine einzige falsche Vorlage erzeugt in fünf Jahren vierundfünfzig fehlerhafte Systeme. Das ist die Kehrseite der Wiederverwendung: Sie verbreitet nicht nur das Richtige, sondern ebenso zuverlässig das Falsche — Ariane 5 aus Band 17 auf der Konfigurationsebene.*

Die beiden Abhilfen.

Ansatz	Aufwand	Wirkung
54 Systeme einzeln	108 h	einmalig
Vorlage berichtigen	**2 h**	alles Künftige
Beides	110 h	**richtig**

Die zweite Zeile allein wirkt nur nach vorn, die erste allein nur nach hinten — und die Vorlage würde weiter kopiert. Das ist die allgemeine Regel bei sich vervielfältigenden Fehlern: Man muss die Quelle und die Kopien angehen, und die Quelle zuerst.

Die Konfiguration ist Teil des Systems

	Quelltext	Konfiguration
Versions-verwaltet	immer	**oft nicht**
Durchgesehen	meist	selten
Geprüft	ja	kaum
Ändert das Verhalten	ja	**ja**

Die letzte Zeile ist bei beiden gleich, alle darüber sind verschieden. Eine Konfigurationsänderung kann ein System öffnen wie eine Codeänderung — und durchläuft keine der Kontrollen, die für Code selbstverständlich sind.

Daraus folgt die wirksamste Einzelmaßnahme dieses Kapitels: Konfiguration wie Code behandeln — versioniert, durchgesehen, maschinell geprüft, aus einer Quelle ausgerollt. Dann gelten alle Verfahren aus Band 17 auch für sie.

Saltzer und Schroeder[21] forderten den geschlossenen Grundzustand; Howard und LeBlanc[8] behandeln sichere Voreinstellungen als Entwurfsaufgabe des Herstellers; Viega und McGraw[27] zeigen, wie Konfiguration Teil der Sicherheitsarchitektur wird.

8 Die Lieferkette

Wieviel fremder Code

Größe	Wert	
Fremdanteil am Code	≈ 80–90 %	typisch
Unmittelbare Abhängigkeiten	≈ 30–60	überschaubar
Mittelbare	**≈ 400–1500**	**nie gelesen**
Betreuer je Paket	oft 1	

Die dritte Zeile ist der Kern: Man wählt dreißig Bibliotheken aus und bekommt tausend. Von den neunhundertsiebzig, die man nicht ausgewählt hat, kennt niemand die Herkunft — und jede läuft mit denselben Rechten wie der eigene Code.

Die Vertrauensfrage.

Frage	Beantwortbar?	
Wer hat es geschrieben?	teils	
Wer darf es ändern?	**meist nicht**	
Entspricht das Paket dem Quelltext?	selten geprüft	**Thompson**
Wird es noch gepflegt?	ja	messbar

Die dritte Zeile ist Thompsons Frage aus dem Begleitband in ihrer heutigen Form: Der veröffentlichte Quelltext und das ausgelieferte Paket sind zwei verschiedene Dinge, und fast niemand prüft, ob sie zusammenpassen. Reproduzierbare Übersetzung ist genau die Antwort darauf.

Die drei Angriffswege

Weg	Vorgehen	Erkennbar?
Namensverwechslung	ähnlicher Paketname	gut
Übernahme	**Betreuer wird abgelöst**	**schwer**
Bauumgebung	Paket weicht vom Quelltext ab	nur reproduzierbar

Die mittlere Zeile ist die unheimlichste, weil sie den sozialen Weg nimmt. Ein einzelner überlasteter Betreuer wird über Monate durch hilfreiche Beiträge entlastet, bekommt einen Mitbetreuer — und der ändert später eine Zeile. Kein technischer Schutz greift hier.

Was hilft

Maßnahme	Aufwand	Wirkung
Abhängigkeiten festnageln	gering	gegen plötzliche Änderung
Stückliste führen	gering	**man weiß, was drin ist**
Bekannte Lücken abgleichen	gering	hoch
Anzahl senken	mittel	**hoch**
Reproduzierbar bauen	hoch	gegen Bauumgebung
Rechte begrenzen	mittel	**begrenzt den Schaden**

Die zweite Zeile ist die Grundlage aller anderen. Ohne Stückliste kann man bei einer bekannt gewordenen Lücke nicht einmal beantworten, ob man betroffen ist — und genau diese Frage hat 2021 weltweit Wochenenden gekostet.

Die letzte Zeile ist die einzige, die auch gegen einen unbekannten Angriff wirkt. Eine Bibliothek, die keine Netzverbindungen aufbauen und keine Dateien außerhalb ihres Bereichs lesen darf, kann auch mit Hintertür wenig anrichten.

Aktualisieren ist zweischneidig

	Sofort aktualisieren	**Festnageln**
Bekannte Lücken	schnell zu	bleiben offen
Untergeschobene Änderung	**kommt mit**	bleibt draußen
Aufwand	gering	mittel

Die beiden ersten Zeilen widersprechen einander — und beide Gefahren sind real. Der übliche Ausweg ist festnageln plus regelmäßiger, geprüfter Aktualisierungslauf: Man bekommt die Behebungen mit Verzögerung und die Hintertüren nicht ungeprüft.

Die Abwägung hängt am Angreifermodell aus Kapitel 2: Gegen Massenangriffe auf bekannte Lücken ist schnelles Aktualisieren richtig, gegen gezielte Lieferkettenangriffe falsch. Wer beides fürchtet, braucht die Zwischenstufe.

Aufgabe 8.1.

(a) Bestimmen Sie die tatsächliche Abhängigkeitsmenge.
(b) Rechnen Sie die Wahrscheinlichkeit einer betroffenen Abhängigkeit aus.
(c) Untersuchen Sie die Wirkung begrenzter Rechte.

Lösung Schritt für Schritt.

(a) Die tatsächliche Abhängigkeitsmenge.
Die Aufnahme. Ein System mit 42 unmittelbaren Abhängigkeiten.

Ebene	neu	kumuliert	Faktor
1	42	42	—
2	186	228	5,4
3	341	569	2,5
4	228	797	1,4
5	94	**891**	1,1

Aus zweiundvierzig gewählten werden achthunderteinundneunzig tatsächliche. Die Kurve flacht ab, weil sich die Bäume überschneiden — viele Pakete hängen von denselben Grundbausteinen ab. Das ist zugleich der Grund, warum eine Lücke in einem dieser Grundbausteine so weit reicht.

Die Verteilung nach Betreuern.

Betreuer	Pakete	Anteil	
1 Person	**487**	**55** %	Risiko
2–4	284	32 %	
> 4	86	10 %	robuster
Unklar	34	4 %	prüfen

Über die Hälfte des fremden Codes wird von je einer Person gepflegt — unbezahlt, meist neben dem Beruf. Das ist keine Anklage, sondern der Befund, auf dem der Übernahmeangriff aus dem Technikkasten beruht.

(b) Wahrscheinlichkeit einer betroffenen Abhängigkeit.
Das Modell. Bei n Paketen und einer Jahreswahrscheinlichkeit p je Paket:

$$P(\text{mindestens eines betroffen}) = 1 - (1 - p)^{n}.$$

n	$p = 10^{-4}$	$p = 10^{-3}$	$p = 10^{-2}$
42	0,004	0,041	0,345
228	0,023	0,205	0,901
891	**0,085**	**0,589**	≈ 1

Der Unterschied zwischen der ersten und der dritten Zeile ist der Preis der mittelbaren Abhängigkeiten. Bei einer Rate von einem Promille steigt die Jahreswahrscheinlichkeit von vier auf neunundfünfzig Prozent — allein dadurch, dass man nicht zählt, was man tatsächlich einbindet.

Die Wirkung des Abbaus.

Maßnahme	*n*	*P*	**Aufwand**
Ausgangslage	891	0,589	—
Kleinstpakete ersetzen	760	0,533	20 h
Zwei schwere Rahmen ablösen	**410**	**0,336**	**180** h
Beides	340	0,288	200 h

Die dritte Zeile trägt die Wirkung: Zwei umfangreiche Rahmenwerke bringen den größten Teil der mittelbaren Abhängigkeiten mit. Der Abbau kostet Wochen und halbiert die Jahreswahrscheinlichkeit — eine Rechnung, die vor der Auswahl eines Rahmenwerks selten aufgemacht wird.

(c) Wirkung begrenzter Rechte.
Die Frage. Was kann eine Bibliothek mit Hintertür anrichten?

Umgebung	**Datenabfluss**	**Dauerhaft**	**Schaden**
Volle Rechte	ja	ja	100 %
Ohne Netzzugang	**nein**	ja	30 %
Ohne Schreibrechte	ja	nein	45 %
Beides begrenzt	nein	nein	**8** %

Eine Bibliothek zum Verarbeiten von Bildformaten braucht keinen Netzzugang. Nimmt man ihn ihr, ist eine Hintertür darin weitgehend wirkungslos — sie kann Daten lesen und nicht wegschaffen. Das ist der Grundsatz der geringsten Rechte, angewandt auf Code statt auf Personen.

Warum es selten gemacht wird.

Grund	Gewicht	
Sprachen bieten es kaum	hoch	**alles im selben Prozess**
Aufwand je Bibliothek	mittel	
Kein sichtbarer Nutzen	hoch	Kapitel 5

Die erste Zeile ist die entscheidende Beschränkung: In den meisten Sprachen laufen alle Bibliotheken im selben Prozess mit denselben Rechten. Wo es Trennmöglichkeiten gibt — eigene Prozesse, Sandkästen, Fähigkeitensysteme — sind sie umständlich und werden deshalb umgangen. Saltzers achter Grundsatz.

Der Fall von 2024

Das Ziel	Eine Kompressionsbibliothek mit einem einzigen Betreuer
Der Weg	Über etwa zwei Jahre Vertrauen aufgebaut, dann Mitbetreuer geworden
Die Hintertür	**Nicht im Quelltext, sondern in den Bauskripten und Prüfdaten**
Entdeckt durch	Eine Zeitmessung, die jemandem auffiel

Drei Lehren. Erstens: Der Angriff nahm den sozialen Weg, gegen den kein Werkzeug hilft. Zweitens: Die Hintertür lag außerhalb des Quelltextes — genau dort, wohin niemand schaut. Drittens: Die Entdeckung war Zufall, und das ist die beunruhigendste der drei.

Die tragfähige Folgerung ist nicht Misstrauen gegen offene Entwicklung — geschlossene Lieferketten sind nicht besser, nur undurchsichtiger. Sie lautet: Wer eine Bibliothek einbindet, sollte wissen, wie viele Menschen dahinterstehen, und die Rechte danach bemessen.

Thompson[26] stellte 1984 die Frage, wem man beim Übersetzen vertraut; Anderson[1] behandelt die Lieferkette als Vertrauensproblem; Zetter[28] beschreibt am Fall Stuxnet, wie weit ein entschlossener Angreifer die Kette hinaufgeht.

9 Der Mensch

Der Satz vom schwächsten Glied

Die Behauptung	Der Mensch sei das schwächste Glied der Sicherheitskette
Was sie leistet	Sie beendet die Untersuchung
Die bessere Frage	**Warum kann eine einzelne Fehlentscheidung alles kosten?**

Ein System, in dem ein falscher Klick zur vollständigen Übernahme führt, hat ein Entwurfsproblem und kein Personalproblem. Das ist Reasons Haltung aus Band 18 in sicherheitstechnischer Anwendung: Wenn viele erfahrene Menschen denselben Fehler machen, liegt es nicht an den Menschen.

Warum Täuschung funktioniert.

Hebel	Wirkung	Gegenmittel
Zeitdruck	**schaltet Prüfen ab**	Verfahren ohne Eile
Autorität	Widerspruch unterbleibt	**Vier-Augen-Regel**
Hilfsbereitschaft	wird ausgenutzt	
Angst	erzeugt Gehorsam	
Gewohnheit	**Muster statt Prüfung**	Band 18, Kap. 5

Die letzte Zeile ist die grundsätzlichste: Wer eine Aufgabe hundertmal ausgeführt hat, erkennt Muster statt zu prüfen. Eine Täuschung, die dem gewohnten Muster entspricht, wird nicht durchschaut — nicht aus Nachlässigkeit, sondern weil das schnelle Denken übernommen hat.

Was gegen Täuschung tatsächlich wirkt

Maßnahme	Wirkung	
Schulung	gering	verblasst in Wochen
Testmails mit Tadel	**schädlich**	man meldet nicht mehr
Meldeweg ohne Vorwurf	hoch	**Frühwarnung**
Sicherheits-schlüssel	**sehr hoch**	**Klasse geschlossen**

Die zweite Zeile ist die wichtigste Warnung: Wer Beschäftigte für das Anklicken einer Testmail tadelt, erzieht sie dazu, Vorfälle zu verschweigen — und verliert damit die einzige Quelle für Frühwarnung. Die vierte Zeile beseitigt den Angriffsweg technisch und macht die Frage nach Schulung nachrangig.

Die Sicherheitskultur

	Schuldkultur	Lernkultur
Nach einem Vorfall	**Wer war es?**	**Was hat es ermöglicht?**
Meldungen	gehen zurück	steigen
Wissen über Lage	schlecht	gut
Wiederholung	wahrscheinlich	unwahrscheinlicher

Die zweite Zeile ist messbar und wird selten gemessen. Ein Haus mit steigenden Meldezahlen wirkt auf den ersten Blick unsicherer und ist in Wahrheit besser dran — es sieht, was geschieht. Sinkende Meldezahlen sind fast nie ein gutes Zeichen.

Der Innentäter ist selten böswillig

Art	Anteil	Gegenmittel
Fahrlässig	**überwiegend**	**Entwurf, Rechte**
Getäuscht	hoch	zweiter Faktor
Böswillig	gering	Aufzeichnung, Trennung

Die Aufmerksamkeit richtet sich auf die letzte Zeile, der Schaden entsteht in der ersten. Gegen Fahrlässigkeit hilft weder Überwachung noch Vertrauensprüfung, sondern nur ein Entwurf, in dem ein einzelner Fehlgriff begrenzten Schaden anrichtet.

Aufgabe 9.1.

(a) Rechnen Sie die Wirkung von Schulung gegen Technik aus.
(b) Bestimmen Sie den Wert eines vorwurfsfreien Meldewegs.
(c) Untersuchen Sie die Vier-Augen-Regel.

Lösung Schritt für Schritt.

(a) Schulung gegen Technik.
Die Lage. 300 Beschäftigte, monatlich eine Täuschungswelle.

Zustand	Klickrate	Zu Übernahme	je Jahr
Ohne Maßnahmen	14 %	2,1 %	**7,6**
Nach Schulung	6 %	0,9 %	3,2
6 Monate später	11 %	1,7 %	6,1
Mit Schlüsseln	14 %	$\approx$ **0**	$\approx$ **0**

Die dritte Zeile ist der Befund, den niemand hören will: Die Schulungswirkung ist nach einem halben Jahr weitgehend verflogen. Die vierte Zeile lässt die Klickrate unverändert und macht sie folgenlos — der Angriffsweg ist geschlossen, nicht die Neigung.

Die Kostenrechnung.

Maßnahme	Einmalig	Jährlich	Wirkung
Schulung, halbjährlich	0	≈ 90 h	−40 %
Schlüssel, 300 **Stück**	≈ **18 000**	≈ 20 h	−**99** %

Achtzehntausend einmalig gegen neunzig Stunden jährlich — und die eine Maßnahme wirkt dauerhaft, die andere verblasst. Bei einem erwarteten Schaden von mehreren zehntausend je Übernahme amortisiert sich die zweite Zeile im ersten Jahr.

Das ist kein Argument gegen Schulung — sie vermittelt, warum die Maßnahmen bestehen, und sorgt dafür, dass sie nicht umgangen werden. Es ist ein Argument dagegen, sie als Schutzmaßnahme *zu führen.*

(b) Der Wert eines vorwurfsfreien Meldewegs.

Kultur	Melde-quote	Mittlere Meldezeit	Schaden
Mit Tadel	≈ 12 %	> 24 h	100 %
Neutral	≈ 35 %	6 h	62 %
Ausdrücklich erwünscht	≈ **78** %	**25 min**	**24** %

Die dritte Spalte trägt die Wirkung. Wer einen Fehlgriff binnen fünfundzwanzig Minuten meldet, ermöglicht das Sperren von Zugangsdaten, bevor sie benutzt werden. Nach vierundzwanzig Stunden ist der Angreifer bereits im System.

Was den Unterschied macht.

Maßnahme	Aufwand	
Meldeknopf im Mailprogramm	gering	**ein Klick**
Zusage der Straffreiheit	keiner	**muss eingehalten werden**
Dank für jede Meldung	gering	
Rückmeldung, was daraus wurde	gering	

Die zweite Zeile kostet nichts und ist die schwerste: Sie muss auch dann gelten, wenn jemand etwas Teures ausgelöst hat. Ein einziger Fall, in dem sie gebrochen wird, setzt die Meldequote für Jahre zurück.

(c) Die Vier-Augen-Regel.
Die Wirkung. Bei unabhängiger Prüfung mit Fehlerrate f je Person:

$$f_{\text{beide}} = f^2 \quad \text{(bei Unabhängigkeit).}$$

f	unabhängig	mit Anlehnung	Faktor
0,10	0,010	0,045	**4,5**
0,05	0,0025	0,021	8,4
0,02	0,0004	0,0075	**19**

(Anlehnung: der Zweite verlässt sich teilweise auf den Ersten)

> *Die dritte Spalte ist der Normalfall: Der Zweite prüft weniger gründlich, weil schon jemand hingesehen hat. Der Gewinn liegt dann nicht bei Faktor hundert, sondern bei drei bis fünf — immer noch erheblich, aber weit unter der Erwartung.*

Wann sie wirkt und wann nicht.

Umstand	Wirksam?	
Beide prüfen unabhängig	**ja**	**ohne Kenntnis der Bewertung**
Zweiter sieht die erste Freigabe	teils	Anlehnung
Beide unter Zeitdruck	nein	
Zweiter ist untergeben	**nein**	Autorität
Bei jedem Vorgang	nein	wird umgangen

Die letzte Zeile ist Saltzers achter Grundsatz: Eine Vier-Augen-Regel für jeden Vorgang wird durch Sammelfreigaben umgangen und ist dann wirkungslos. Sie gehört auf wenige, folgenreiche Vorgänge — Zahlungen über einer Schwelle, Rechtevergaben, Auslieferungen.

Der Angreifer kennt die Verfahren

Öffentlich	Organigramme, Zuständigkeiten, Abwesenheiten
Nutzbar	**Anruf während der Urlaubsvertretung**
Wirksam	Wer neu ist, kennt die Verfahren am wenigsten

Gezielte Täuschung nutzt Wissen über das Haus, das öffentlich verfügbar ist. Die zweite Zeile beschreibt den Regelfall bei Zahlungsanweisungsbetrug: Der Anruf kommt, wenn die zuständige Person abwesend ist und eine Vertretung entscheidet, die das Verfahren nicht kennt.

Die Abhilfe ist wieder ein Entwurf, kein Appell: Ein Verfahren, das ohne Ausnahme gilt — auch für Vorgesetzte, auch bei Eile, auch in Vertretung — entzieht der Täuschung ihren Hebel. Eine Regel mit Ausnahmen wird über die Ausnahme angegriffen.

Mitnick[15] beschreibt die Hebel der Täuschung aus der Sicht des Täters; Florêncio und Herley[7] zeigten früh, dass verbreitete Passwortforderungen an menschlichen Grenzen scheitern; Shostack[24] bezieht den Menschen als Angriffsweg in die Bedrohungsmodellierung ein.

Part IV

Was sich verrät

10 Seitenkanäle

Ein Bauteil verrät mehr als seine Schnittstelle

Kanal	Was verrät sich	Erstmals
Zeit	**Rechenweg**	1996
Stromaufnahme	Schlüsselbits	1999
Zwischenspeicher	**Zugriffsmuster**	2005
Ausführungs-vorhersage	**fremder Speicher**	2018
Geräusch, Abstrahlung	Tastenanschläge	

Alle diese Kanäle haben eines gemeinsam: Sie tragen keine Daten im Sinne der Schnittstelle. Ein Programm, das nur seine Ausgabe betrachtet, ist korrekt — und verrät über die Dauer seiner Arbeit trotzdem, welchen Weg es genommen hat.

Der einfachste Fall.

Der Code	Vergleicht zwei Zeichenketten und bricht beim ersten Unterschied ab
Die Wirkung	**Je mehr Zeichen stimmen, desto länger dauert es**
Die Folge	Ein Geheimnis lässt sich zeichenweise erraten

Aus einem Suchraum von z^l wird einer von $z \cdot l$. Bei sechzehn Zeichen aus einem Vorrat von 64 sind das statt 10^{29} Versuchen genau 1024 — der Unterschied zwischen unmöglich und einer Minute.

Vergleich in gleichbleibender Zeit

	Früher Abbruch	Konstante Zeit
Dauer	**hängt vom Inhalt ab**	immer gleich
Vorgehen	bricht ab	**alle Zeichen, Ergebnis verodert**
Kosten	schneller	unmerklich

Die Abhilfe ist billig und muss bewusst gewählt werden: Man vergleicht immer alle Zeichen und verknüpft die Einzelergebnisse, statt beim ersten Unterschied auszusteigen. Jede Bibliothek für Kryptographie bietet eine solche Funktion — und die eingebaute Zeichenkettenoperation der Sprache ist nicht sie.

Wenn die Hardware sich verrät

Der Mechanismus	Der Prozessor rechnet spekulativ voraus, bevor die Berechtigung geklärt ist
Die Rücknahme	Das Ergebnis wird verworfen — die Spuren im Zwischenspeicher nicht
Die Messung	**Über Zugriffszeiten liest man ab, was spekulativ geladen wurde**

Die zweite Zeile ist der Kern: Die Rücknahme war architektonisch vollständig und mikroarchitektonisch nicht. Zwanzig Jahre lang galt dieser Unterschied als bedeutungslos — er ist die Grundlage einer ganzen Angriffsklasse.

Die Lehre reicht über die Hardware hinaus: Eine Abstraktion verbirgt Details, und ein Angreifer misst genau die Details, die sie verbirgt. Was die Ebene darunter tut, bleibt beobachtbar, auch wenn die Schnittstelle es nicht vorsieht.

Die Gegenmaßnahmen kosten Leistung

Maßnahme	Einbuße	Wirkung	
Getrennte Adressräume	5–30 %	hoch	je nach Last
Spekulations-bremsen	2–15 %	hoch	
Kerntrennung abschalten	≈ 15 %	hoch	teuer
Zusammen	≈ **20–40** %		**bei geteilten Anlagen**

Das ist der Preis, den die Wolke aus Band 16 zahlt: Wo mehrere Kunden dieselbe Hardware teilen, sind alle Maßnahmen nötig, und ein Fünftel bis zwei Fünftel der Rechenleistung gehen dafür weg. Auf einem Rechner mit nur einem Nutzer ist der Aufwand meist unnötig.

Die Entscheidung hängt wieder am Angreifermodell: Teilt sich fremder Code die Maschine? Wenn nein, sind die Maßnahmen Kosten ohne Nutzen. Wenn ja, sind sie unverzichtbar.

Aufgabe 10.1.

(a) Rechnen Sie einen Zeitangriff durch.
(b) Bestimmen Sie die nötige Zahl der Messungen.
(c) Untersuchen Sie, wo Seitenkanäle praktisch zählen.

Lösung Schritt für Schritt.

(a) Ein Zeitangriff.
Die Lage. Ein Sitzungsmerkmal, 16 Zeichen aus 64 möglichen, verglichen mit frühem Abbruch.

Ansatz	Versuche	
Vollständig durchprobieren	$64^{16} \approx 8 \cdot 10^{28}$	aussichtslos
Zeichenweise	$\mathbf{64 \cdot 16 = 1024}$	**Minuten**
Mit Mittelung, $n = 200$	204 800	Stunden

Sechsundzwanzig Größenordnungen Unterschied zwischen der ersten und der zweiten Zeile — allein durch die Frage, ob der Vergleich beim ersten Unterschied abbricht. Die dritte Zeile ist die realistische: Über das Netz muss man mitteln, um das Rauschen zu schlagen.

Das Vorgehen.

1	Probiere alle 64 Zeichen an Stelle 1, miss jeweils die Antwortzeit.
2	Das Zeichen mit der **längsten** Zeit ist das richtige.
3	Halte es fest, gehe zu Stelle 2.
4	Nach 16 Runden ist das Merkmal bekannt.

Der Unterschied je Stelle beträgt wenige Nanosekunden — über das Netz gemessen verschwindet er im Rauschen einzelner Messungen und tritt im Mittel über viele hervor. Genau das leistet die Mittelung in der dritten Tabellenzeile.

(b) Die nötige Zahl der Messungen.
Das Signal-Rausch-Verhältnis. Der Unterschied sei $\Delta = 40$ ns, die Streuung der Netzlaufzeit $\sigma = 400$ µs.

$$n \approx \left(\frac{k\,\sigma}{\Delta} \right)^2$$

mit $k \approx 3$ für eine zuverlässige Unterscheidung:

$$n \approx \left(\frac{3 \cdot 4 \cdot 10^{-4}}{4 \cdot 10^{-8}} \right)^2 = \left(3 \cdot 10^{4} \right)^2 = \mathbf{9 \cdot 10^{8}}.$$

Ort der Messung	σ	Messungen	Dauer
Über Internet	400 μs	$9 \cdot 10^8$	unpraktisch
Im selben Netz	20 μs	$2{,}3 \cdot 10^6$	Stunden
Auf derselben Maschine	200 ns	**225**	**Sekunden**

Die Nähe entscheidet über die Durchführbarkeit. Über das Internet ist der Angriff eine Rechenübung; auf derselben Maschine dauert er Sekunden. Das ist der Grund, warum Seitenkanäle bei geteilten Anlagen ein reales Problem sind und bei einer Anwendung hinter einer Netzverbindung meist keines.

Die Rechnung zeigt auch, warum die Abhilfe trotzdem eingebaut gehört: Sie kostet fast nichts, und die Annahme „niemand ist auf derselben Maschine“ gilt in der Wolke nicht.

(c) Wo Seitenkanäle praktisch zählen.

Lage	Zählt?	Grund
Geteilte Wolkenmaschine	**ja**	**fremder Code daneben**
Browser mit fremdem Skript	ja	
Chipkarte in fremder Hand	**ja**	**physischer Zugriff**
Anwendung hinter Netz	selten	Rauschen
Rechner im Tresor	nein	

Die dritte Zeile ist die älteste und praktisch bedeutsamste: Eine Chipkarte gibt der Angreifer nicht aus der Hand, sondern hält sie in der Hand — er kann Strom, Zeit und Abstrahlung beliebig oft messen. Deshalb sind Seitenkanäle dort seit den neunziger Jahren Entwurfsthema.

Die Verhältnismäßigkeit.

Maßnahme	Aufwand	Wirkung	Rang
Konstantzeit-vergleich	Minuten	hoch	**1**
Geprüfte Kryptobibliothek	gering	hoch	2
Getrennte Adressräume	mittel	hoch	3
Eigene Hardware	sehr hoch	voll-ständig	4
Eigene Kryptographie schreiben	hoch	**negativ**	—

Die letzte Zeile ist ernst gemeint: Selbstgeschriebene kryptographische Grundfunktionen sind fast immer seitenkanalanfällig, weil die Vermeidung Fachwissen verlangt, das man beim Schreiben nicht bemerkt zu brauchen. Kapitel 11 führt das aus.

Die Abstraktion verbirgt, der Angreifer misst

Ebene	Verbirgt	Verrät
Sprache	Speicherlage	Laufzeit
Betriebssystem	andere Prozesse	Zwischen-speicher
Virtualisierung	andere Kunden	**Zeitverhalten**
Prozessor	Ausführungs-reihenfolge	**Spekulation**

Jede Abstraktionsschicht aus Band 16 macht dasselbe Versprechen — du musst nicht wissen, was darunter geschieht — und jede bricht es an derselben Stelle: Die darunterliegende Ebene bleibt messbar. Ein Seitenkanal ist nichts anderes als eine Abstraktion, durch die man hindurchsieht.

Kocher[10] zeigte 1996, dass Zeitmessung Schlüssel preisgibt; die Arbeiten zu Spectre[11] und Meltdown[14] übertrugen den Gedanken auf die spekulative Ausführung und trafen damit fast jeden Prozessor im Feld.

11 Kryptographie in der Anwendung

Die Mathematik ist nicht das Problem

Bruchstelle	Häufigkeit	
Verfahren mathematisch gebrochen	sehr selten	
Falsch angewendet	**häufig**	**Betriebsart, Zufall**
Schlüssel-verwaltung	**sehr häufig**	
Veraltetes weiterbenutzt	häufig	

Band 8 behandelt die erste Zeile — und sie ist die seltenste Bruchstelle. Wer ein System angreift, bricht nicht RSA, sondern findet den Schlüssel in einer Konfigurationsdatei. Das ist keine Geringschätzung der Mathematik, sondern eine Aussage über die Praxis.

Die klassischen Anwendungsfehler.

Fehler	Folge	
Betriebsart ohne Verkettung	**Muster bleiben sichtbar**	Bild erkennbar
Einmalwert wiederverwendet	**Schlüssel ableitbar**	
Schwacher Zufall	Schlüssel vorhersagbar	
Verschlüsselt ohne Echtheitsschutz	**Angreifer ändert unbemerkt**	
Eigene Konstruktion	alles davon	

Die vierte Zeile ist die meistunterschätzte: Verschlüsselung allein schützt die Vertraulichkeit und nicht die Unversehrtheit. Wer eine verschlüsselte Nachricht verändern kann, ohne dass es auffällt, kann oft mehr anrichten als jemand, der sie liest.

Kerckhoffs' Grundsatz

Der Satz	Ein Verfahren muss sicher bleiben, wenn alles außer dem Schlüssel bekannt ist
Der Grund	**Verfahren werden bekannt — Schlüssel lassen sich wechseln**
Die Probe	Was passiert, wenn der Quelltext veröffentlicht wird?

Der Grundsatz ist hundertdreiundvierzig Jahre alt und wird jedes Mal verletzt, wenn ein Hersteller sein Verfahren geheim hält, statt es prüfen zu lassen. Die Geschichte kennt keinen einzigen Fall, in dem ein geheim gehaltenes Verfahren dauerhaft geheim blieb — und viele, in denen es nach der Veröffentlichung binnen Tagen gebrochen war.

Schlüsselverwaltung

Frage	Schwierigkeit	
Erzeugen	gelöst	Zufallsquelle des Systems
Verteilen	**schwer**	**das eigentliche Problem**
Aufbewahren	schwer	
Wechseln	**sehr schwer**	Altdaten
Zurückziehen	schwer	

Die vierte Zeile ist der Punkt, an dem viele Systeme scheitern: Ein Schlüsselwechsel verlangt, dass alte Daten mit dem alten und neue mit dem neuen Schlüssel behandelt werden — also eine Versionierung, die von Anfang an mitgedacht sein muss. Wer sie nachrüstet, muss den gesamten Bestand umschlüsseln.

Deshalb lautet die praktische Regel: Jeder verschlüsselte Datensatz trägt die Kennung seines Schlüssels mit sich. Das kostet ein paar Bytes und macht den Wechsel von einem Projekt zu einer Routine.

Selbstbau ist der häufigste Fehler

Ebene	Selbst bauen?	
Grundfunktionen	**nie**	
Betriebsarten	nie	
Protokolle	**nie**	Kapitel 12
Anwendung fertiger Bausteine	ja	das ist die Aufgabe

Der Grund ist nicht mangelndes Können, sondern die Prüfbarkeit: Eine selbstgebaute Konstruktion sieht funktionierend aus, weil sie ver- und entschlüsselt. Ob sie sicher ist, zeigt kein Test — das ist Rice' Satz aus Band 2 in praktischer Gestalt.

Die vernünftige Wahl sind heute Bibliotheken, die keine Auswahl anbieten: eine Funktion zum Verschlüsseln, eine zum Entschlüsseln, keine Parameter für Betriebsart oder Auffüllung. Was man nicht wählen kann, kann man nicht falsch wählen.

Aufgabe 11.1.

(a) Zeigen Sie, was ein wiederverwendeter Einmalwert preisgibt.
(b) Rechnen Sie die Kosten eines Schlüsselwechsels aus.
(c) Bestimmen Sie die Restlaufzeit heutiger Verfahren.

Lösung Schritt für Schritt.

(a) Ein wiederverwendeter Einmalwert.
Die Lage. Eine Stromchiffre verschlüsselt durch Verodern mit einem Schlüsselstrom, der aus Schlüssel und Einmalwert erzeugt wird.

$$C_1 = M_1 \oplus S, \qquad C_2 = M_2 \oplus S.$$

Die Folge.

$$C_1 \oplus C_2 = (M_1 \oplus S) \oplus (M_2 \oplus S) = M_1 \oplus M_2.$$

Der Schlüsselstrom hebt sich heraus. Übrig bleibt die Verknüpfung zweier Klartexte — ohne jede Kenntnis des Schlüssels. Wer einen der beiden Texte kennt oder erraten kann, hat den anderen.

Was daraus folgt.

Bekannt	Ergebnis	
Ein Klartext ganz	**der andere ganz**	
Ein Klartextanfang	der andere Anfang	**Briefköpfe**
Beide unbekannt	statistisch angreifbar	natürliche Sprache
n Texte, gleicher Wert	**alle**	

Die zweite Zeile ist der praktische Einstieg: Nachrichten beginnen mit vorhersagbaren Teilen — Kopfzeilen, Anreden, Formatangaben. Wer sechzehn Byte errät, hat sechzehn Byte des anderen Textes.

Ursache der Wiederholung	Häufigkeit	
Zähler bei Neustart zurückgesetzt	häufig	
Zufallswert zu kurz	**häufig**	**Geburtstags-problem**
Fest im Code	kommt vor	

Die zweite Zeile lässt sich beziffern: Bei einem 64-bit-Zufallswert ist nach etwa 2^{32} Nachrichten mit Wahrscheinlichkeit $1/2$ eine Wiederholung dabei — das sind vier Milliarden, und bei einem stark genutzten Dienst keine unerreichbare Zahl. Bei 96 bit liegt die Grenze bei 2^{48}.

(b) Kosten eines Schlüsselwechsels.
Die Lage. 80 Millionen verschlüsselte Datensätze.

Vorgehen	Dauer	Ausfall	Risiko
Alles auf einmal	14 h	**14 h**	hoch
Im Hintergrund	6 Wochen	keiner	gering
Beim Zugriff	**Monate**	keiner	**gering**

Die Voraussetzung für die letzten beiden Zeilen.

Merkmal	Vorhanden?	
Schlüsselkennung je Satz	**nötig**	2 Byte
Mehrere Schlüssel gleichzeitig gültig	nötig	
Nachweis über den Fortschritt	nötig	

Zwei Byte je Datensatz — 160 Megabyte bei achtzig Millionen Sätzen — verwandeln einen vierzehnstündigen Ausfall in eine unbemerkte Hintergrundarbeit. Das ist eine der günstigsten Entwurfsentscheidungen dieses Bandes, und sie muss vor dem ersten Datensatz getroffen werden.

(c) Restlaufzeit heutiger Verfahren.

Verfahren	Klassisch	Mit Quantenrechner	Bewertung
AES-128	sicher	64 bit wirksam	ausreichend
AES-256	sicher	128 bit	**sicher**
SHA-256	sicher	128 bit	sicher
RSA-2048	sicher	**gebrochen**	**ersetzen**
Elliptische Kurven	sicher	**gebrochen**	ersetzen

Die Asymmetrie ist scharf: Symmetrische Verfahren verlieren die halbe Schlüssellänge, asymmetrische fallen ganz. Band 15 führt aus, warum — Grover halbiert den Exponenten, Shor löst das zugrunde liegende Problem.

Die Dringlichkeit.

Frage	Antwort	
Gibt es solche Rechner?	nein	Band 15
Wann?	unbekannt	
Warum trotzdem jetzt?	**Heute abgefangene Daten lassen sich später entschlüsseln**	

Die letzte Zeile ist das ganze Argument und wird oft übersehen. Für Daten mit langer Schutzdauer — Gesundheitsakten, Verträge, Staatsgeheimnisse — zählt nicht, wann der Rechner kommt, sondern wie lange die Daten geheim bleiben müssen. Was heute mitgeschnitten wird, wird dann gelesen.

Schutzdauer	Dringlichkeit	
Tage	keine	Sitzungsdaten
5 Jahre	gering	
30 Jahre	**hoch**	**Patientendaten**
$>$ 50 Jahre	sehr hoch	

Die dritte Zeile betrifft jeden, der Gesundheitsdaten führt: Eine heute übertragene Akte muss noch in dreißig Jahren geschützt sein. Wer sie mit einem asymmetrischen Verfahren austauscht, das dann gebrochen ist, hat sie faktisch offen übertragen.

Der Umstieg hat begonnen

Stand	Bewertung	
Normen verabschiedet	seit 2024	
Bibliotheken vorhanden	ja	
Übliches Vorgehen	**Mischbetrieb**	alt *und* neu
Schlüssel und Signaturen	größer	Übertragung, Speicher

Der Mischbetrieb ist die kluge Zwischenlösung: Man kombiniert ein bewährtes mit einem neuen Verfahren, sodass ein Bruch eines *von beiden nicht genügt. Damit ist man weder auf das alte noch auf das neue angewiesen — gestufte Verteidigung aus Kapitel 1, auf Kryptographie angewandt.*

Kerckhoffs[9] formulierte 1883 den Grundsatz, der die Geheimhaltung des Verfahrens ausschließt; Beurdouche und Mitautoren[3] zeigten, wie Anwendungsfehler in Protokollen entstehen; Anderson[1] behandelt die Schlüsselverwaltung als das eigentliche Problem der Praxis.

12 Protokolle und Zustände

Der Zustandsautomat ist die Schwachstelle

Geprüft wird	Üblich?	
Jede einzelne Nachricht	ja	Format, Signatur
Die Reihenfolge	**oft nicht**	
Das Auslassen	**selten**	**Schritt übersprungen**
Die Wiederholung	teils	

Ein Protokoll ist ein Zustandsautomat, und die Fehler sitzen nicht in den Nachrichten, sondern in den Übergängen. Eine Umsetzung, die jede Nachricht korrekt behandelt und dabei nicht prüft, ob sie an dieser Stelle erlaubt ist, lässt Wege zu, die im Entwurf nicht vorkommen.

Das Muster.

1	Der Entwurf sieht die Schritte $A \to B \to C$ vor.
2	Die Umsetzung behandelt A, B und C je in einer Funktion.
3	Es fehlt die Prüfung, ob C nach A kommen darf.
4	**Der Angreifer sendet A, dann C — und überspringt die Prüfung in B.**

Dieses Muster wurde 2015 in mehreren unabhängigen Umsetzungen desselben Protokolls gefunden — durch eine systematische Erkundung der Zustandsautomaten. Alle waren einzeln geprüft worden; keine war als Automat geprüft worden.

Warum die Zustandsprüfung fehlt

Die Norm	Beschreibt den erlaubten Ablauf in Prosa
Die Umsetzung	**Bildet die Nachrichten ab, nicht den Automaten**
Der Prüfstand	Prüft gültige Abläufe — ungültige kommen nicht vor

Die dritte Zeile ist der Kern: Prüfungen werden gegen den gedachten Ablauf geschrieben. Ein Angreifer folgt ihm nicht — und genau die Übergänge, die niemand vorgesehen hat, werden auch von niemandem geprüft. Man müsste die unerlaubten *Wege durchgehen, und die sind zahlreicher.*

Wiedereinspielung und Frische

Mittel	Schützt gegen	Preis
Zeitstempel	Wiedereinspielung	Uhrensynchronität
Laufende Nummer	Wiedereinspielung	Zustand nötig
Zufallswert vom Prüfer	**Wiedereinspielung**	eine Runde mehr
Nichts	–	

Die dritte Zeile ist die verlässlichste: Wer die Antwort an einen Wert bindet, den er selbst gerade gewählt hat, kann eine alte Antwort nicht akzeptieren. Zeitstempel scheitern in der Praxis regelmäßig an ungenauen Uhren — und dann werden die Toleranzfenster so weit, dass sie nichts mehr leisten.

Die Herabstufung.

Der Angriff	Der Angreifer schaltet die Aushandlung auf ein schwaches Verfahren
Die Voraussetzung	**Das schwache Verfahren ist noch vorhanden**
Die Abhilfe	Alte Verfahren entfernen, nicht nur nachrangig stellen

Das ist wieder die Angriffsfläche aus Kapitel 3: Ein Verfahren, das aus Rücksicht auf alte Gegenstellen weiter angeboten wird, ist erreichbar — und der Angreifer wählt es aus, nicht die Gegenstelle. Verträglichkeit und Sicherheit stehen hier in direktem Widerspruch.

Die Aushandlung muss gebunden sein

Aufbau	**Herabstufbar?**	
Aushandlung ungeschützt	ja	**Angreifer ändert Liste**
Aushandlung später bestätigt	nein	fällt auf

Der Kunstgriff ist einfach und musste mehrfach nachgerüstet werden: Am Ende des Verbindungsaufbaus bestätigen beide Seiten kryptographisch, was sie zu Beginn ausgehandelt zu haben glauben. Stimmen die Angaben nicht überein, hat jemand dazwischen etwas geändert.

Aufgabe 12.1.

(a) Zählen Sie die Übergänge eines Protokollautomaten.
(b) Prüfen Sie einen Ablauf auf übersprungene Schritte.
(c) Rechnen Sie die Wirkung des Entfernens alter Verfahren aus.

Lösung Schritt für Schritt.

(a) Die Übergänge zählen.
Der Automat. Sechs Zustände, zehn Nachrichtenarten.

Größe	Wert	
Zustände	6	
Nachrichtenarten	10	
Mögliche Übergänge	**60**	6×10
Im Entwurf vorgesehen	14	
Ungeprüft	**46**	77 %

Vierzehn gewollte Übergänge und sechsundvierzig ungewollte. Die Prüfungen decken die vierzehn ab — die anderen sechsundvierzig sind das, was der Angreifer probiert. Das Verhältnis erklärt, warum diese Fehlerklasse so hartnäckig ist.

Die Abhilfe.

Ansatz	Aufwand	Wirkung
Alle 46 prüfen	hoch	vollständig
Automat ausformulieren	mittel	**alles Unerlaubte fällt**
Maschinelle Erkundung	mittel	findet Abweichungen

Die mittlere Zeile ist der strukturelle Griff: Wer den Automaten als Tabelle hinschreibt und jede Nachricht dagegen prüft, muss die sechsundvierzig nicht einzeln behandeln — sie fallen alle in denselben Zweig. Wieder das Muster „Fehler unmöglich machen“ statt „Fehler vermeiden“.

(b) Ein Ablauf mit übersprungenem Schritt.
Der gedachte Ablauf.

1	Anfrage	Kunde meldet Warenkorb
2	**Zahlung**	**Dienst bestätigt Eingang**
3	Bestätigung	Bestellung wird angelegt
4	Versand	

Der Angriff.

1	Anfrage	normal
3	**Bestätigung direkt**	**Zahlung übersprungen**
4	Versand	Ware ohne Bezahlung

Möglich wird das, wenn Schritt 3 nur prüft, ob eine gültige Bestellnummer vorliegt — und nicht, ob diese Bestellung im Zustand „bezahlt“ ist. Beide Prüfungen sehen ähnlich aus; nur die zweite ist eine Zustandsprüfung.

Die Prüfliste für jeden Schritt.

1	Ist der Vorgang im richtigen Zustand für diesen Schritt?
2	Kommt die Bestätigung aus einer vertrauenswürdigen Quelle?
3	Ist sie frisch, also nicht wiedereingespielt?
4	Bezieht sie sich auf **diesen** Vorgang und diesen Betrag?

Frage vier wird am häufigsten vergessen: Eine echte, frische Zahlungsbestätigung über fünf Euro wird auf eine Bestellung über fünfhundert angewandt. Die Bestätigung ist gültig — sie gehört nur zu einem anderen Vorgang.

(c) Alte Verfahren entfernen.
Die Lage. Ein Dienst bietet sieben Verschlüsselungsverfahren an.

Verfahren	Nutzung	Bewertung	Behalten?
Aktuell A	87 %	gut	ja
Aktuell B	11 %	gut	ja
Älter C	1,8 %	schwächer	prüfen
Alt D	0,2 %	schwach	**nein**
Alt E–G	$<$ 0,05 %	**gebrochen**	**nein**

Vier von sieben Verfahren werden von weniger als einem halben Prozent der Verbindungen genutzt und tragen das gesamte Herabstufungsrisiko. Das Entfernen kostet zwei Stunden und schließt die Gegenstellen aus, die ohnehin niemand mehr pflegt.

Die Abwägung.

Folge des Entfernens	Umfang	
Betroffene Verbindungen	≈ 0,25 %	
Davon echte Nutzer	≈ 60	ansprechbar
Aufwand für diese	≈ 20 h	Umstellungshilfe
Gewinn	**Herabstufungsweg geschlossen**	

Sechzig Gegenstellen sind ansprechbar, und die zwanzig Stunden Umstellungshilfe sind die ehrlichere Rechnung als das dauerhafte Offenhalten. Wer alte Verfahren „vorläufig“ behält, behält sie auf Dauer — die Bequemlichkeitsfalle aus Kapitel 7.

Selbstgebaute Protokolle

Was zu bedenken ist	Vergessen?	
Frische	oft	Wiederein-spielung
Bindung an den Vorgang	**oft**	**Teil (b)**
Zustandsprüfung	oft	
Herabstufung	oft	
Fehlermeldungen als Kanal	fast immer	Kapitel 10

Fünf Dinge, an die ein etabliertes Protokoll nach zwanzig Jahren Prüfung denkt und eine Eigenkonstruktion nach zwei Wochen nicht. Der Rat aus Kapitel 11 gilt hier genauso — und aus demselben Grund: Das Selbstgebaute funktioniert sichtbar und versagt unsichtbar.

Beurdouche und Mitautoren[3] deckten durch systematische Erkundung der Zustandsautomaten Fehler in mehreren Umsetzungen desselben Protokolls auf; Bishop[4] behandelt Protokolle als Zustandssysteme; Stuttard und Pinto[25] zeigen die Erscheinungsformen im Web.

Part V

Verteidigung

13 Härten

Die Rangfolge der Maßnahmen

Maßnahme	Aufwand	Wirkung	Rang
Zeitnah aktualisieren	gering	sehr hoch	**1**
Zweiter Faktor	gering	sehr hoch	**2**
Getrennte Sicherungen	gering	sehr hoch	**3**
Ungenutztes abschalten	gering	hoch	4
Geringste Rechte	mittel	hoch	5
Netzsegmentierung	mittel	hoch	6
Aufzeichnung	mittel	hoch	7
Sichere Voreinstellungen	gering	hoch	8
Fortlaufende Prüfung	mittel	mittel	9
Angriffserkennung	hoch	mittel	10
Prüfung durch Dritte	hoch	punktuell	11

Die oberen acht sind billig und wirksam; die unteren drei sind teuer und wirken punktuell. Trotzdem beginnen viele Häuser unten — weil die unteren sichtbar sind und Berichte erzeugen, während die oberen unauffällig bleiben.

Die Reihenfolge folgt dem Angreifermodell.

Häufigste Wege	Maßnahme	
Bekannte Lücke	**Rang 1**	
Gestohlene Zugangsdaten	**Rang 2**	
Erpressung	**Rang 3**	senkt den Ertrag
Vergessene Schnittstelle	Rang 4	

Die vier obersten Maßnahmen decken die vier häufigsten Wege ab — das ist kein Zufall, sondern die Rangfolge nach Erwartungswert aus Kapitel 2. Wer nach Schlagzeilen priorisiert, kommt zu einer anderen Reihenfolge und schützt gegen das Seltenere.

Sicherheit in den Bauvorgang holen

Zeitpunkt	Kosten	
Beim Entwurf	1	**Bedrohungsmodell**
Beim Schreiben	3	Typen, gebundene Parameter
In der Prüfstrecke	6	automatisch
Bei der Abnahme	20	
Im Betrieb	**100**+	**Vorfall**

Dieselbe Kurve wie in Band 17 — und aus demselben Grund: Nicht der Fehler wird teurer, sondern das Wiedereinarbeiten. Die dritte Zeile hat das beste Verhältnis, weil sie ohne menschliche Aufmerksamkeit auskommt.

Was in die Prüfstrecke gehört.

Prüfung	Dauer	Findet
Abhängigkeiten abgleichen	< 30 s	**bekannte Lücken**
Geheimnisse suchen	< 20 s	Schlüssel im Code
Statische Analyse	2–8 min	Fehlerklassen
Verkettungen aufspüren	< 10 s	Einschleusung
Konfiguration prüfen	< 30 s	Fehlkonfiguration

Vier der fünf Prüfungen brauchen unter einer Minute und passen damit in die Rückmeldedauer aus Band 17, Kapitel 10. Was länger dauert, wandert in den nächtlichen Lauf — sonst wird es abgeschaltet.

Der Schwellenwert entscheidet über die Wirkung

Einstellung	Meldungen	Verhalten
Alles melden	> 500	**ignoriert**
Nur Schweres	≈ 12	wird gelesen
Bau abbrechen bei Schwerem	≈ 12	**wird behoben**

Dieselbe Beobachtung wie in Band 17, Kapitel 8: Ein Werkzeug mit niedriger Trefferquote erzieht dazu, seine Meldungen zu übergehen — und dann werden auch die richtigen übergangen. Wenige verlässliche Meldungen sind mehr wert als viele mögliche.

Aufgabe 13.1.

(a) Stellen Sie einen Härtungsplan nach Wirkung je Aufwand auf.
(b) Rechnen Sie die Wirkung zeitnaher Aktualisierung aus.
(c) Bestimmen Sie, was eine Prüfung durch Dritte leistet.

Lösung Schritt für Schritt.

(a) Ein Härtungsplan.
Die Lage. Mittelständisches Haus, 200 Arbeitsplätze, kein eigenes Sicherheitsteam.

Maßnahme	Stunden	Risiko −	je Stunde
Sicherungen trennen	24	32 %	**1,33**
Zweiter Faktor	60	28 %	0,47
Aktualisierung ordnen	40	**34** %	**0,85**
Dienstkonten entrechten	32	18 %	0,56
Ungenutztes abschalten	60	14 %	0,23
Segmentierung	200	22 %	0,11
Aufzeichnung	120	10 %	0,08

Die letzte Spalte ordnet die Arbeit. Getrennte Sicherungen und geordnete Aktualisierung stehen oben, obwohl beide unspektakulär sind — und die Segmentierung, die in jedem Vortrag vorkommt, steht weit unten, weil sie zweihundert Stunden kostet.

Der Plan über ein Jahr.

Quartal	Maßnahmen	Aufwand
1	Sicherungen, Aktualisierung	64 h
2	Zweiter Faktor	60 h
3	Dienstkonten, Abschalten	92 h
4	Aufzeichnung beginnen	120 h
Summe		**336 h**

Dreihundertsechsunddreißig Stunden — gut zwei Personenmonate — für die Maßnahmen mit dem besten Verhältnis. Die Segmentierung steht bewusst nicht darin; sie kommt, wenn das Obenstehende erledigt ist.

(b) Wirkung zeitnaher Aktualisierung.
Das Zeitfenster. Zwischen Veröffentlichung einer Behebung und ihrer Einspielung.

Verzögerung	Massenangriffe erreichen	Trefferwahrsch.	
< 24 h	selten	0,02	gut
1 Woche	beginnend	0,12	
1 Monat	voll	0,38	
6 Monate	voll	**0,71**	hoch
Nie	—	$\approx$ **0,95**	**sicher betroffen**

Die Kurve steigt in den ersten Wochen steil, weil automatisierte Suchläufe nach Bekanntwerden einer Lücke binnen Tagen anlaufen. Wer innerhalb von vierundzwanzig Stunden einspielt, entgeht der Masse fast vollständig — danach wird jeder Tag teurer.

Der Einwand und seine Auflösung.

Einwand	Berechtigt?	Auflösung
„Aktualisierungen brechen Dinge“	ja	**Prüfumgebung**
„Kein Wartungsfenster“	teils	Redundanz
„Zu viele Systeme“	ja	**automatisieren**

Alle drei Einwände sind real, und alle drei sind Aufgaben, keine Gründe. Die dritte ist die wichtigste: Was von Hand eingespielt wird, wird verspätet eingespielt — und die Verzögerung ist die Größe, die den Schaden bestimmt.

(c) Prüfung durch Dritte.

Art	Findet	Grenze
Werkzeuglauf	bekannte Muster	nichts Neues
Eindringprüfung	**einen Weg**	**nicht alle**
Quelltextprüfung	Fehlerklassen	teuer
Bedrohungs-modell	**Entwurfs-fehler**	früh, billig

Die zweite Zeile enthält die wichtigste Einschränkung: Eine Eindringprüfung beweist, dass ein Weg besteht — nicht, dass keiner mehr besteht, wenn sie keinen findet. Sie ist die Asymmetrie aus Kapitel 1 als Dienstleistung.

Der übliche Ablauf und sein Ertrag.

Befundklasse	Anzahl	Vorher bekannt	
Kritisch	2	0	**Ertrag**
Hoch	6	2	
Mittel	19	11	
Gering	47	38	Rauschen

Der Ertrag liegt in der ersten Zeile: zwei kritische Befunde, die niemand kannte. Die vierundsiebzig übrigen sind größtenteils bekannt oder unbedeutend — und binden bei der Nachbearbeitung mehr Zeit als die beiden wichtigen.

Daraus folgt eine Empfehlung, die selten ausgesprochen wird: Eine Eindring-prüfung lohnt sich erst, wenn die Rangfolge aus dem ersten Kasten abgearbeitet ist. Vorher findet sie, was man ohnehin wusste — und kostet das Vielfache der Behebung.

Der Bericht ist nicht die Verbesserung

Schritt	Erledigt?	
Prüfung beauftragt	ja	
Bericht erhalten	ja	
Befunde behoben	**oft nicht**	**kein Budget mehr**
Nachprüfung	selten	

Wer eine Prüfung beauftragt, sollte das Behebungsbudget vorher einplanen — erfahrungsgemäß in der Größenordnung des Prüfungsauftrags. Ein Bericht ohne Behebung verschlechtert die Lage sogar: Er dokumentiert, dass man von den Lücken wusste.

Shostack[24] zeigt, wie Bedrohungsmodellierung Entwurfsfehler früh und billig findet; Viega und McGraw[27] behandeln Sicherheit als Teil des Bauvorgangs; Howard und LeBlanc[8] liefern die Handgriffe für die Prüfstrecke.

14 Erkennen und Reagieren

Die Zeit ist die entscheidende Größe

Abschnitt	Typisch	Ziel
Eindringen bis Entdeckung	**Wochen bis Monate**	Stunden
Entdeckung bis Eindämmung	Tage	Stunden
Eindämmung bis Wiederanlauf	Wochen	Tage

Die erste Zeile bestimmt den Schaden. Ein Angreifer, der Wochen Zeit hat, erkundet das Netz, legt weitere Zugänge an und findet die Sicherungen — ein Angreifer, der nach zwei Stunden auffällt, hat einen Arbeitsplatz. Der Unterschied ist nicht graduell.

Was man aufzeichnen muss.

Ereignis	Aufwand	Wert
Anmeldungen, auch fehlgeschlagene	gering	**sehr hoch**
Rechteänderungen	gering	**sehr hoch**
Neue Konten	gering	sehr hoch
Zugriffe auf Sicherungen	gering	hoch
Ausgehende Verbindungen	mittel	hoch
Jeder Datenzugriff	hoch	mittel

Die ersten drei Zeilen kosten fast nichts und decken die Handlungen ab, die ein Angreifer nach dem Eindringen immer *ausführt: sich anmelden, Rechte ausweiten, sich einen dauerhaften Zugang schaffen. Wer nur diese drei aufzeichnet und auswertet, hat den größten Teil des Nutzens.*

Die Aufzeichnung muss außer Reichweite sein

Ort	Löschbar?	
Auf dem System selbst	**ja**	**erste Handlung des Angreifers**
Auf einem Sammelserver	bei Übernahme	
Schreibgeschützt, extern	**nein**	brauchbar

Aufzeichnungen, die der Angreifer löschen kann, sind keine Aufzeichnungen. Das Löschen ist zudem selbst ein Ereignis — wo eine Lücke im Protokoll auftaucht, weiß man wenigstens, wann etwas geschah, auch wenn man nicht mehr weiß, was.

Der Vorfall

1	**Feststellen** — ist es ein Vorfall oder eine Störung?
2	**Eindämmen** — Ausbreitung stoppen, ohne Spuren zu zerstören
3	**Aufklären** — Weg, Umfang, Zeitraum
4	**Bereinigen** — Zugänge schließen, Systeme neu aufsetzen
5	**Wiederanlauf** — geordnet, mit Beobachtung
6	**Auswerten** — was hat gefehlt?

Schritt 2 enthält einen Zielkonflikt, der unter Druck falsch entschieden wird: Wer sofort alles abschaltet, stoppt den Angreifer und zerstört die Spuren, die zeigen würden, wie weit er kam. Wer zu lange zusieht, verliert mehr Daten. Die Entscheidung gehört vorbereitet, nicht improvisiert.

Was vorher festliegen muss.

Frage	Vorher klären	
Wer entscheidet?	**eine Person**	**namentlich**
Wer darf abschalten?	ja	
Wie erreicht man einander?	**ja**	**nicht über das eigene Netz**
Wann wird gemeldet?	ja	Fristen
Wer spricht nach außen?	ja	

Die dritte Zeile wird regelmäßig übersehen und ist im Ernstfall entscheidend: Wenn die Erpressungssoftware auch die Telefonanlage und das Postfach erfasst hat, braucht man Nummern auf Papier. Ein Notfallplan, der nur im betroffenen System liegt, ist keiner.

Fehlalarme bestimmen die Wirksamkeit

Fehlalarme/Tag	Verhalten	
< 5	jeder wird geprüft	
20	Auswahl	
200	**ignoriert**	**Erkennung wertlos**

Dieselbe Grenze wie bei den Prüfwerkzeugen in Kapitel 13 und bei den Alarmen in Three Mile Island aus Band 18. Ein Erkennungssystem, das zweihundert Meldungen am Tag erzeugt, hat die Erkennung nicht verbessert, sondern verlagert — vom System zu einem Menschen, der sie nicht bewältigt.

Aufgabe 14.1.

(a) Rechnen Sie mit Erkennungs- und Fehlalarmraten.
(b) Bestimmen Sie den Wert der Verkürzung der Verweildauer.
(c) Prüfen Sie einen Wiederanlaufplan.

Lösung Schritt für Schritt.

(a) Erkennungs- und Fehlalarmrate.
Die Lage. 2 Millionen Ereignisse täglich, davon 8 bösartige.

Fehlalarmrate	Fehlalarme	Echte Treffer	Genauigkeit
10^{-3}	2000	7	**0,35 %**
10^{-4}	200	7	3,4 %
10^{-5}	20	7	26 %
10^{-6}	2	6	**75 %**

(bei einer Erkennungsrate von 85 %, in der letzten Zeile 75 %)

> *Das ist das Grundproblem seltener Ereignisse. Bei einer Fehlalarmrate von einem Promille — die für ein Prüfverfahren gut klingt — sind neunundneunzig Komma sechs Prozent aller Meldungen falsch. Die Rate muss um drei Größenordnungen besser sein, damit die Meldungen brauchbar werden.*

Die Auflösung.

Ansatz	Wirkung	
Schwelle anheben	weniger Alarme	übersieht mehr
Mehrere Merkmale verknüpfen	**hoch**	**Rate multipliziert sich**
Nach Bereich staffeln	hoch	wenige wichtige Systeme
Bekanntes ausschließen	hoch	Grundrauschen kennen

Die zweite Zeile ist die wirksamste: Zwei unabhängige Merkmale mit je 10^{-3} ergeben zusammen 10^{-6} — dieselbe Multiplikation wie bei der gestuften Verteidigung, hier zugunsten der Erkennung. Die Bedingung ist wieder die Unabhängigkeit.

(b) Der Wert kürzerer Verweildauer.

Verweildauer	Was der Angreifer schafft	Schaden	
2 h	ein Arbeitsplatz	8 %	gering
1 Tag	Netz erkundet	22 %	
1 Woche	weitere Zugänge	55 %	
1 Monat	**Sicherungen gefunden**	**100** %	voll

Die letzte Zeile ist die entscheidende Schwelle: Wer die Sicherungen erreicht, kann sie mitverschlüsseln — und damit fällt der einzige verlässliche Schutz gegen Erpressung weg. Deshalb sind getrennte Sicherungen und schnelle Erkennung dieselbe Maßnahme, von zwei Seiten betrachtet.

Die Rechnung.

Posten	Wert	
Vorfälle je Jahr	0,4	
Vollschaden	900 000	
Erwartungswert ohne Erkennung	**360 000**	
Erwartungswert bei 1 Tag	79 000	
Ersparnis	**281 000**	gegen 120 h Einrichtung

Die Rechnung trägt auch bei vorsichtigeren Annahmen: Selbst bei einem Zehntel der angesetzten Vorfallhäufigkeit übersteigt der erwartete Nutzen den Aufwand deutlich. Das ist die Robustheitsprüfung aus Kapitel 3.

(c) Einen Wiederanlaufplan prüfen.
Die Probe. Nicht die Sicherung zählt, sondern die Wiederherstellung.

Frage	Geprüft?	
Sicherung läuft	meist	
Rückspielung getestet	**selten**	**der eigentliche Test**
Dauer gemessen	selten	
Sicherung vom Netz getrennt	oft nicht	**mitverschlüsselt**
Reihenfolge festgelegt	selten	Abhängigkeiten

Die zweite Zeile ist die klassische Lücke: Sicherungen laufen jahrelang fehlerfrei, und beim ersten Ernstfall stellt sich heraus, dass sie unvollständig oder unlesbar sind. Eine Sicherung, die nie zurückgespielt wurde, ist eine Vermutung.

Die gemessene Wiederanlaufzeit.

Schritt	Geplant	Gemessen	Faktor
Hardware bereitstellen	2 h	9 h	4,5
Grundsystem	1 h	3 h	3,0
Daten zurückspielen	4 h	**17** h	4,3
Prüfen und freigeben	1 h	6 h	6,0
Summe	**8 h**	**35 h**	**4,4**

Faktor vierkommavier zwischen Planung und Übung — eine verlässliche Erfahrungsregel. Wer eine Wiederanlaufzeit zusagt, ohne sie gemessen zu haben, sagt ein Viertel der Wahrheit zu.

Die Übung ist die einzige Prüfung

Art	Aufwand	Erkenntnis
Plan schreiben	16 h	gering
Plan durchsprechen	4 h	mittel
Teil zurückspielen	8 h	**hoch**
Vollständige Übung	40 h	sehr hoch

Die dritte Zeile hat das beste Verhältnis: Ein Teilrückspielen auf Ersatzgerät kostet einen Arbeitstag und findet die meisten Fehler — fehlende Schlüssel, unvollständige Sicherungen, unbekannte Abhängigkeiten. Vierteljährlich durchgeführt ersetzt es die große Übung fast vollständig.

Das ist zugleich die Antwort auf den Satz „Wir hatten noch nie einen Vorfall“ aus Kapitel 1: Ohne Übung weiß man nicht, ob der Plan trägt — und ohne Aufzeichnung nicht, ob wirklich nichts geschehen ist.

Reason[20] entwickelte den Umgang mit organisatorischen Unfällen, aus dem die Vorfallbehandlung stammt; Leveson[13] zeigt, dass Reaktion Teil des Systementwurfs ist; Perrow[19] beschreibt, warum eng gekoppelte Systeme Störungen schlecht vertragen.

Part VI

Bilanz

15 Der Stand im Jahr 2026

Was wirkt und was behauptet wird

Maßnahme	Beleglage	Urteil
Zeitnahe Aktualisierung	eindeutig	unstrittig
Zweiter Faktor	eindeutig	**stärkste Einzelmaßnahme**
Getrennte Sicherungen	eindeutig	gegen Erpressung
Geringste Rechte	gut	unstrittig
Segmentierung	gut	begrenzt Schaden
Speichersichere Sprachen	gut	**schließt Klasse**
Sichere Voreinstellungen	gut	größter Hebel
Schulung gegen Täuschung	gemischt	verblasst
Erzwungener Passwortwechsel	negativ	**schädlich**
Zertifizierungen als Beleg	keine	Nachweis, nicht Schutz
Erkennungssoftware allein	begrenzt	eine Stufe

Die obere Gruppe ist unspektakulär und seit Jahrzehnten bekannt — es sind fast alles Maßnahmen, die Wege schließen oder Schaden begrenzen. Keine davon erscheint in Werbeprospekten, weil man sie nicht kaufen kann.

Fünf Entwicklungen

Erstens: Werkzeuge, die Angriffe finden und schreiben.

Wirkung auf	Seite	
Lücken finden	beide	
Täuschungstexte	**Angreifer**	**fehlerfrei, angepasst**
Code durchsehen	Verteidiger	
Aufwand je Angriff	sinkt	mehr Angreifer

Die zweite Zeile ist die klarste Verschiebung: Der sprachliche Fehler war jahrzehntelang das verlässlichste Erkennungsmerkmal einer Täuschungsmail. Er ist verschwunden — und damit ein Ratschlag, der in jeder Schulung stand.

Die letzte Zeile beschreibt die eigentliche Veränderung: Nicht die Angriffe werden besser, sondern billiger. Damit lohnen sich Ziele, die vorher unter der Kostenschwelle aus Kapitel 2 lagen — kleine Häuser, Vereine, Praxen.

Zweitens: Erpressung als Geschäftszweig.

Merkmal	Wirkung	
Arbeitsteilung	hoch	Zugang, Werkzeug, Verhandlung getrennt
Doppelte Erpressung	**Sicherung genügt nicht**	**Daten werden vorher kopiert**
Ziele	alle Größen	

Die zweite Zeile hat die Lage verändert: Wer nur verschlüsselt wird, stellt aus der Sicherung wieder her. Wer zusätzlich mit Veröffentlichung bedroht wird, dem hilft keine Sicherung — hier wirkt nur, die Daten gar nicht erst zu haben oder verschlüsselt zu halten.

Drittens: Die Hardware ist keine feste Grundlage mehr.

Annahme	Hält?	
Prozessgrenzen trennen	einge-schränkt	**Seitenkanäle**
Verschlüsselung im Speicher	teils	
Behebung durch Aktualisierung	**nur teilweise**	Leistungsverlust

Seit 2018 ist klar, dass Trennung im Prozessor nicht vollständig ist. Die Gegenmaßnahmen kosten Rechenleistung, und einige Klassen lassen sich nur durch geänderte Bauart schließen — also frühestens in der übernächsten Gerätegeneration.

Viertens: Regulierung greift ein.

Vorgabe	Ab	
Meldepflichten	seit Jahren	
Erweiterte Pflichten, EU	**seit 2024**	mehr Branchen
Produkt-anforderungen	**ab 2027**	**Hersteller in der Pflicht**

Die dritte Zeile ist die folgenreichste: Sie verlagert Anforderungen vom Betreiber zum Hersteller — und damit dorthin, wo die Voreinstellungen entschieden werden, also an den größten Hebel aus Kapitel 7.

Fünftens: Passwortlose Verfahren verbreiten sich.

Eigenschaft	Wirkung	
Kein Geheimnis beim Dienst	**Diebstahl wertlos**	
An die Seitenadresse gebunden	**Täuschung wirkungslos**	
Nichts zu merken	hoch	**Band 18, Kap. 2**
Geräteverlust	neues Problem	Wiederher-stellung

Die ersten drei Zeilen schließen die beiden häufigsten Angriffswege gegen Konten gleichzeitig. Die letzte ist die offene Frage: Der Wiederherstellungsweg nach Geräteverlust ist bei vielen Umsetzungen der schwächste Punkt — und damit genau das, was der Titel dieses Bandes meint.

Drei Einsichten

Erstens: Die Asymmetrie bleibt.

Was sich änderte	Richtung	
Werkzeuge des Angreifers	billiger	
Werkzeuge des Verteidigers	besser	
Systemgröße	**gewachsen**	**mehr Wege**
Verhältnis	**eher schlechter**	

Die dritte Zeile schlägt die zweite. Bessere Werkzeuge helfen dem Verteidiger, aber sein Aufwand wächst mit der Zahl der Wege — und die ist schneller gewachsen als die Werkzeuge besser geworden sind.

Zweitens: Die Klassen sind alt.

Klasse	Bekannt seit	Noch aktuell?
Pufferüberlauf	1988	**ja**
Einschleusung	1998	**ja**
Fehlende Rechteprüfung	1975	ja
Standard-kennwörter	1980er	ja
Täuschung	**uralt**	ja

Keine dieser Klassen ist ungelöst — für jede gibt es eine bekannte, billige Abhilfe. Sie sind ein Umsetzungsproblem, kein Erkenntnisproblem, und stehen damit in einer Reihe mit Band 17 und Band 18.

Drittens: Der Entwurf schlägt die Wachsamkeit.

Ansatz	Verlangt	Haltbarkeit
Aufmerksamkeit	**dauernd**	verblasst
Verfahren	Einhaltung	erodiert
Entwurf	**einmal**	**dauerhaft**

Gebundene Parameter, speichersichere Sprachen, Sicherheitsschlüssel, geschlossene Voreinstellungen — alle wirksamen Maßnahmen dieses Bandes machen einen Fehler unmöglich, *statt ihn unwahrscheinlich zu machen. Das ist der Unterschied zwischen einem Faktor und einer Null.*

Was dieser Band nicht verspricht

Erwartung	Erfüllbar?	
Sicheres System	**nein**	gibt es nicht
Kein Vorfall mehr	nein	
Angriffe teurer machen	**ja**	
Schaden begrenzen	**ja**	
Schneller bemerken	ja	

Die unteren drei Zeilen sind das, was erreichbar ist — und sie genügen. Ein Angriff, der zu teuer ist, findet nicht statt; einer, der stattfindet, bleibt auf ein Segment beschränkt; und einer, der bemerkt wird, endet nach Stunden statt nach Monaten.

Wer mehr verspricht, verkauft etwas. Das ist die letzte Anwendung des Leitgedankens: Ohne benannten Gegner ist „sicher“ keine Aussage — und mit benanntem Gegner wird aus der Behauptung eine Rechnung.

Alle wirksamen Maßnahmen dieses Bandes haben eines gemeinsam:
Sie verlassen sich nicht darauf, dass jemand aufpasst.

Sie machen den Fehler unmöglich,
statt ihn unwahrscheinlich zu machen.

— die Bilanz dieses Bandes.
Denn Aufmerksamkeit verblasst, Verfahren erodieren —
und ein Entwurf hält.

Schneier[23] beschreibt die gesellschaftlichen Folgen vernetzter unsicherer Systeme; die OWASP-Liste[18] zeigt die Beständigkeit der Fehlerklassen; Bonneau und Mitautoren[5] untersuchten früh, woran Passwortnachfolger scheitern und welche Eigenschaften ein Ersatz haben muss.

Part VII

Anhang

A Formeln und Kenngrößen

Die Formeln

Alle Wege sicher	$P = p^n$
Mindestens eine Lücke	$P = 1 - (1 - f)^n$
Gestufte Verteidigung	$P(\text{Erfolg}) = q^k$
Angriffsfläche	$A = \sum_i e_i \, r_i \, d_i$
Kostenschwelle	$\text{Ertrag} \cdot P > \text{Aufwand}$
Passwortentropie	$H = l \, \log_2 z$
Vier-Augen-Regel	$f_{\text{beide}} = f^2$ (bei Unabhängigkeit)

Die erste, dritte und letzte Formel setzen Unabhängigkeit voraus — und genau diese Annahme trägt in der Praxis am seltensten. Wer sie benutzt, sollte zuerst prüfen, ob die Wege wirklich getrennt sind.

Die wichtigsten Zahlen

Größe	Wert	Kapitel
Speicherfehler an schweren Lücken	60–70 %	4
Aufwandsverhältnis bei 1000 Wegen	$\approx$ 231:1	1
Voreinstellung wird geändert von	5–10 %	7
Ungenutzte Endpunkte nach 12 Jahren	$\approx$ 38 %	3
Mittelbare Abhängigkeiten	400–1500	8
Pakete mit einem Betreuer	$\approx$ 55 %	8
Fremdanteil am Code	80–90 %	8
Entropie: vier zufällige Wörter	$\approx$ 52 bit	6
Empfohlene Mindestlänge	$\geq$ 12 Zeichen	6
Schulungswirkung nach 6 Monaten	≈ 0	9
Meldequote mit Straffreiheit	$\approx$ 78 %	9

Alle Werte sind Größenordnungen aus verschiedenen Erhebungen. Die Verhältnisse sind belastbarer als die absoluten Zahlen — und auf Verhältnissen beruhen die Argumente dieses Bandes.

Die acht Grundsätze und die sechs Bedrohungen

1	Sparsamer Aufbau — je einfacher, desto prüfbarer
2	**Grundhaltung verboten — erlaubt wird ausdrücklich**
3	Vollständige Prüfung — bei jedem Zugriff, nicht beim ersten
4	Offener Entwurf — die Sicherheit liegt im Schlüssel
5	Geteilte Zuständigkeit — zwei Bedingungen statt einer
6	**Geringste Rechte — nur so viel, wie die Aufgabe braucht**
7	Wenig Gemeinsames — geteilte Bauteile verbinden
8	**Annehmbarkeit — was zu umständlich ist, wird umgangen**

Bedrohung	**Verletzt**	**Gegenmittel**
Vortäuschen	Echtheit	Anmeldung
Verfälschen	Unversehrtheit	Signaturen
Abstreiten	Nachweisbarkeit	Aufzeichnung
Preisgeben	Vertraulichkeit	Rechte
Lahmlegen	Verfügbarkeit	Begrenzung
Rechte ausweiten	Befugnis	geringste Rechte

Die acht Grundsätze prüft man an einem Entwurf, die sechs Bedrohungen an jeder Vertrauensgrenze. Beides zusammen ist eine Stunde Arbeit und findet mehr als jedes Werkzeug.

B Landkarte und Glossar

Wo was steht

Kap.	Thema	Verweise
1	Asymmetrie	Band 17
2	Angreifermodell	
3	Angriffsfläche	**Band 17**
4	Speicherfehler	**Band 0, Band 17**
5	Einschleusung	**Band 10, Band 16**
6	Rechte und Identität	**Band 8, Band 18**
7	Konfiguration	Band 17
8	Lieferkette	**Begleitband, Band 17**
9	Der Mensch	**Band 18**
10	Seitenkanäle	**Band 4, Band 7**
11	Kryptographie in der Anwendung	**Band 8**
12	Protokolle	**Band 2, Band 9**
13	Härten	Band 17
14	Erkennen	Band 13
15	Stand 2026	Band 18

Begriffe

Angreifermodell	Wer angreift, womit, woher, wogegen
Angriffsfläche	Eingänge mal Rechte mal erreichbare Daten
Asymmetrie	Verteidiger braucht alle Wege, Angreifer einen
Bedrohungs-modellierung	Vier Fragen an Aufbau und Grenzen
Einschleusung	Daten werden als Anweisung gedeutet
Gebundene Parameter	Daten getrennt von der Anweisung übergeben
Geringste Rechte	Nur so viel Befugnis wie nötig
Kerckhoffs-Grundsatz	Sicherheit liegt im Schlüssel, nicht im Verfahren
Kostenschwelle	Angriff findet statt, wenn er sich lohnt
Seitenkanal	Ein Bauteil verrät mehr als seine Schnittstelle
Stückliste	Verzeichnis aller enthaltenen Bestandteile
Vertrauensgrenze	Linie, jenseits derer andere Annahmen gelten

C Zeittafel

Von 1883 bis 2026

1883	**Kerckhoffs: die Sicherheit liegt im Schlüssel**
1961	Erste Passwörter im Zeitteilbetrieb
1972	Anderson-Bericht zur Rechnersicherheit
1974	Lampson: die Zugriffsmatrix
1975	**Saltzer, Schroeder: acht Grundsätze**
1979	Morris, Thompson: Passwortsicherheit
1984	**Thompson: Reflections on Trusting Trust**
1988	Morris-Wurm
1993	Firewalls werden Standard
1995	SSL, später TLS
1996	**Kocher: Zeitmessung als Angriff**
1996	Pufferüberläufe systematisch beschrieben
2000	Schneier: Sicherheit ist ein Vorgang
2001	Viega, McGraw: sichere Software bauen
2002	Mitnick: der Mensch als Angriffsweg
2003	Howard, LeBlanc: sicheres Programmieren
2006	Speicherschutzmaßnahmen werden Standard

2010	**Stuxnet: Schadsoftware zerstört Anlagen**
2012	Bonneau u. a.: warum Passwortnachfolger scheitern
2013	Umfang staatlicher Überwachung wird öffentlich
2014	Heartbleed: eine fehlende Längenprüfung
2014	**Shostack: Bedrohungsmodellierung als Handwerk**
2015	Protokollzustände als eigene Fehlerklasse
2017	**NIST kehrt die Passwortregeln um**
2017	Erpressungssoftware trifft Kliniken
2018	**Meltdown und Spectre**
2020	Lieferkettenangriff auf Verwaltungssoftware
2021	Eine Protokollierbibliothek erschüttert das Netz
2024	**Hintertür in einer Kompressionsbibliothek**
2024	Erweiterte EU-Pflichten in Kraft
2026	Werkzeuge finden und schreiben Angriffe
2027	Produktanforderungen für Hersteller

Zwei Zeilen verdienen eine Anmerkung.
2014, Heartbleed. Eine fehlende Prüfung, ob eine angegebene Länge zur tatsächlichen passt — der Fehler aus Kapitel 4 in seiner folgenreichsten Ausprägung. Die Bibliothek war weltweit im Einsatz und wurde von wenigen Personen gepflegt: Kapitel 8, drei Jahre vor der Debatte darüber.
2017, NIST. Die Abkehr vom erzwungenen Passwortwechsel ist die bekannteste Kehrtwende des Fachs — und ein Beispiel dafür, wie lange eine widerlegte Regel überlebt: Sie steht bis heute in Vorschriften, die sich auf ältere Fassungen derselben Behörde berufen.

D Kommentierte Quellen

[1] Anderson, R.: *Security Engineering*. 3. Aufl., Wiley 2020.

Das Standardwerk, und zwar mit Abstand. *Über tausend Seiten über Banken, Waffensysteme, Wahlmaschinen, Medizingeräte — Sicherheit als Ingenieurdisziplin mit Fallbeispielen statt Rezepten. Frei verfügbar. Wenn Sie ein Buch lesen, dieses.*

[2] Bellovin, S.: *Thinking Security*. Addison-Wesley 2015.

Über das Bilden von Angreifermodellen für die eigene Lage. Bellovins Grundfrage — wogegen genau schützen wir uns eigentlich — ist die nützlichste Übung dieses Fachs und wird am seltensten gemacht.

[3] Beurdouche, B., u. a.: *A Messy State of the Union*. IEEE S&P 2015.

Untersuchte die Zustandsautomaten verbreiteter TLS-Umsetzungen und fand in fast allen Übergänge, die es nicht geben dürfte. Der beste Beleg dafür, dass Protokollfehler nicht in der Kryptographie sitzen, sondern in ihrer Ablaufsteuerung.

[4] Bishop, M.: *Computer Security: Art and Science*. 2. Aufl., Addison-Wesley 2018.

Das strengste Lehrbuch, mit formalen Modellen und Beweisen. Trocken und gründlich — die Ergänzung zu Anderson, wenn man die Grundlagen und nicht die Fälle braucht.

[5] Bonneau, J., u. a.: *The Quest to Replace Passwords*. IEEE S&P 2012.

Bewertet über dreißig Passwortnachfolger nach fünfundzwanzig Kriterien. Das ernüchternde Ergebnis: Keiner ist in allem besser, und deshalb hat sich lange keiner durchgesetzt. Die Kriterienliste ist bis heute der Maßstab.

[6] Dowd, M., McDonald, J., Schuh, J.: *The Art of Software Security Assessment*. Addison-Wesley 2006.

Die gründlichste Darstellung der Fehlerklassen aus Sicht der Prüfung. Zeigt, wie man Code systematisch durchsieht — und was man dabei übersieht. Alt, technisch unverändert gültig.

[7] Florêncio, D., Herley, C.: *A Large-Scale Study of Web Password Habits*. WWW 2007.

Maß, wie viele Passwörter Menschen tatsächlich benutzen und wie oft sie wiederverwenden. Der Befund führte zu der Einsicht, dass Passwortvorschriften an einer biologischen Grenze scheitern und nicht an Nachlässigkeit.

[8] Howard, M., LeBlanc, D.: *Writing Secure Code*. 2. Aufl., Microsoft Press 2003.

Sicheres Programmieren als Handwerk, aus der Erfahrung eines großen Herstellers. Enthält die Begründung für sichere Voreinstellungen aus Herstellersicht — der größte Hebel aus Kapitel 7.

[9] Kerckhoffs, A.: *La cryptographie militaire*. Journal des sciences militaires 1883.

Der älteste noch gültige Grundsatz des Fachs. *Sechs Forderungen an Feldchiffren, von denen die zweite berühmt wurde: Das Verfahren darf in Feindeshand fallen, ohne dass die Sicherheit leidet.*

[10] Kocher, P.: *Timing Attacks on Implementations of Diffie-Hellman, RSA, DSS*. CRYPTO 1996.

Eröffnete die Seitenkanalanalyse: Aus der Rechendauer lässt sich der Schlüssel ableiten, auch wenn die Mathematik unangreifbar ist. Zwölf Seiten, die eine ganze Forschungsrichtung begründeten.

[11] Kocher, P., u. a.: *Spectre Attacks: Exploiting Speculative Execution*. IEEE S&P 2019.

Zeigt, dass die spekulative Ausführung aus Band 4 Daten über Zwischenspeicherzeiten preisgibt. Die Klasse lässt sich nicht vollständig durch Aktualisierung schließen — sie steckt in der Bauart.

[12] Lampson, B.: *Protection*. ACM SIGOPS 1974.

Führt die Zugriffsmatrix ein — Subjekte gegen Objekte, in jeder Zelle die erlaubten Vorgänge. Das Werkzeug für die Rechteprüfung aus Kapitel 6 und der Ursprung fast aller späteren Rechtemodelle.

[13] Leveson, N.: *Engineering a Safer World*. MIT Press 2011.

Behandelt Sicherheit als Systemeigenschaft statt als Summe von Bauteileigenschaften. Auf Anlagensicherheit gemünzt und auf Rechnersysteme übertragbar; die Analyse von Unfallursachen ist strenger als alles Vergleichbare im IT-Bereich. Frei verfügbar.

[14] Lipp, M., u. a.: *Meltdown: Reading Kernel Memory from User Space*. USENIX Security 2018.

Der Nachweis, dass Prozessgrenzen im Prozessor nicht vollständig trennen. Zusammen mit Spectre der Punkt, an dem die Hardware aufhörte, als feste Grundlage zu gelten.

[15] Mitnick, K.: *The Art of Deception*. Wiley 2002.

Beschreibt die Hebel der Täuschung aus der Sicht eines Täters. Als Quelle mit Vorsicht zu lesen — die Fälle sind nacherzählt und ausgeschmückt — und in der Analyse der Hebel unübertroffen.

[16] MITRE: *CWE Top 25 Most Dangerous Software Weaknesses*. Fortlaufend.

Die jährlich aktualisierte Rangliste der Fehlerklassen, aus gemeldeten Schwachstellen berechnet. Nützlich als Bestandsaufnahme — und als Beleg dafür, wie wenig sich an der Spitze ändert.

[17] NIST: *SP 800-63B, Digital Identity Guidelines*. 2017, fortgeschrieben.

Die Kehrtwende bei den Passwortregeln. *Kein erzwungener Wechsel, keine Zeichenklassenvorschriften, dafür Länge und Abgleich gegen Sperrlisten. Kurz, begründet und in vielen Häusern bis heute nicht angekommen.*

[18] OWASP: *Top Ten*. Fortlaufend.

Die bekannteste Liste der Web-Fehlerklassen. Ihr Wert liegt weniger in der Rangfolge als in den Erläuterungen: Zu jeder Klasse steht die Abhilfe, und die ist meist billiger, als man erwartet.

[19] Perrow, C.: *Normal Accidents*. Basic Books 1984.

Über Systeme, in denen Unfälle zum Normalbetrieb gehören. *Perrows Kriterien — enge Kopplung und komplexe Wechselwirkungen — treffen auf moderne IT-Landschaften so genau zu wie auf die Kernkraft, für die er sie aufstellte.*

[20] Reason, J.: *Managing the Risks of Organizational Accidents*. Ashgate 1997.

Enthält das Modell der aufgereihten Löcher: Ein Unfall geschieht, wenn die Lücken mehrerer Schutzschichten zufällig übereinanderliegen. Die beste Begründung für gestufte Verteidigung, die dieses Fach nicht selbst hervorgebracht hat.

[21] Saltzer, J., Schroeder, M.: *The Protection of Information in Computer Systems*. Proc. IEEE 63(9), 1975.

Die acht Grundsätze. *Fünfzig Jahre alt, unverändert gültig und regelmäßig verletzt. Wer nur einen Aufsatz zur Sicherheit liest, sollte diesen lesen — er ist kurz und in klarem Englisch geschrieben.*

[22] Schneier, B.: *Secrets and Lies*. Wiley 2000.

Das Buch, in dem Schneier seine frühere Position widerrief: Sicherheit sei kein mathematisches Problem, sondern ein fortlaufender Vorgang mit Menschen darin. Ein Fachmann, der öffentlich seine Meinung ändert — selten und lehrreich.

[23] Schneier, B.: *Click Here to Kill Everybody*. Norton 2018.

Über die Folgen, wenn unsichere Systeme physische Wirkung haben. Politischer als seine früheren Bücher und in der Diagnose zutreffend: Ein Softwarefehler, der ein Fahrzeug steuert, ist etwas anderes als einer in einer Tabellenkalkulation.

[24] Shostack, A.: *Threat Modeling: Designing for Security*. Wiley 2014.

Das nützlichste Buch für die tägliche Arbeit. *Macht aus Bedrohungsmodellierung ein Handwerk mit vier Fragen, das ohne Werkzeuge und ohne Fachjargon auskommt. Der erste Schritt — ein Diagramm mit Vertrauensgrenzen — findet die meisten Probleme.*

[25] Stuttard, D., Pinto, M.: *The Web Application Hacker's Handbook*. 2. Aufl., Wiley 2011.

Systematisch, gründlich und aus der Prüferperspektive geschrieben. Trotz des Titels kein Rezeptbuch, sondern eine Ordnung der Fehlerklassen im Web — in Einzelheiten veraltet, in der Systematik gültig.

[26] Thompson, K.: *Reflections on Trusting Trust*. CACM 27(8), 1984.

Drei Seiten über die Grenze des Vertrauens. *Ein Übersetzer, der eine Hintertür in jeden neuen Übersetzer schreibt, ohne dass sie im Quelltext steht. Der Begleitband dieser Reihe behandelt den Fall ausführlich; hier ist er die Grundlage von Kapitel 8.*

[27] Viega, J., McGraw, G.: *Building Secure Software*. Addison-Wesley 2001.

Das erste Buch, das Sicherheit als Entwurfsaufgabe behandelte statt als nachträgliche Prüfung. Vieles davon ist heute Allgemeingut — was daran liegt, dass dieses Buch es dazu gemacht hat.

[28] Zetter, K.: *Countdown to Zero Day*. Crown 2014.

Die genaueste Darstellung des Stuxnet-Falls, journalistisch gearbeitet und technisch belastbar. Zeigt, wie weit ein Angreifer mit staatlichen Mitteln geht — und damit zugleich, wie wenig dieser Fall über gewöhnliche Systeme aussagt.

Wenn Sie nur drei Bücher kaufen

[1]	**Anderson**	Für das Fach in seiner ganzen Breite
[24]	**Shostack**	Für die tägliche Arbeit am Entwurf
[21]	**Saltzer, Schroeder**	**Für die Grundsätze — kein Buch, ein Aufsatz**

Anderson liefert das Fach, Shostack das Handwerk, Saltzer und Schroeder die Grundsätze. Auffällig ist, was fehlt: kein Buch über Werkzeuge und keines über Angriffe. Beides veraltet schneller, als es gedruckt werden kann.

Zwei Ergänzungen: [26] Thompson, drei Seiten über Vertrauen, die man in zwanzig Minuten liest. Und [19] Perrow — kein IT-Buch, und die beste Erklärung dafür, warum eng gekoppelte Systeme Unfälle als Normalbetrieb haben.